SHIELD-AI(TM) Assessment Guide – Consultant's Field Manual

Pillar & Control Breakdown with Assessment Methodology

Security Architecture Practice

September 28, 2026

Introduction

How to Use This Document

This is the **SHIELD-AI Assessment Guide** – a field manual for consultants evaluating an organisation's agentic AI security posture. It is structured for use during client engagements:

- **Section 1-7** – Pillar-by-pillar control breakdown. Use during the Assess phase (Weeks 3-4) to score each control and gather evidence.
- **Section 8** – Assessment methodology. How to run the engagement, who to interview, what to inspect.
- **Section 9** – Maturity progression paths. Per-pillar guidance for moving from L1 to L4, aligned with regulatory obligations.
- **Section 10** – Regulatory cross-reference. Quick lookup of which controls satisfy which obligations.

Each control entry includes:

- **Explanation** – what the control does and why it matters
- **Key Assessment Questions** – questions to ask the client team
- **Artifacts to Examine** – specific documents, configurations, and logs to request
- **L1-L4 Indicators** – what compliance looks like at each maturity level
- **Regulatory Mapping** – which AU/international frameworks this control satisfies

Section 1: Model Security (MS)

Pillar Overview

Model Security addresses the security of the AI model itself – its weights, its training pipeline, its inference behaviour, its supply chain, and its ongoing operational integrity. Unlike traditional software, ML models can be compromised during training (data poisoning, backdoor insertion), during distribution (supply chain substitution), or at inference time (prompt injection, jailbreaking, adversarial inputs). Each attack vector requires distinct controls.

Why this matters to the client: A compromised model undermines every decision the agent makes. A backdoored model in a financial services agent could approve fraudulent transactions for months. Unlike a software vulnerability (which can be patched), a poisoned model may require complete retraining – a process that can take weeks or months and cost millions.

Primary stakeholders to interview: ML Engineering Lead, AI Platform Lead, Model Governance Officer, Data Science Manager.

MS-01: Model Weight Protection

Explanation Model weights represent the trained intelligence of an AI system – often the single most valuable intellectual property an organisation has deployed. If weights are exfiltrated, an attacker can clone the model, extract training data through model inversion attacks, or analyse weights for embedded vulnerabilities. Weight protection covers encryption at rest and in transit, HSM-backed key management, and remote attestation for edge deployments.

Key Assessment Questions

1. Are model weights encrypted at rest? Which encryption standard and key management system?
2. Are model weights encrypted during transit between training infrastructure, storage, and inference endpoints?
3. Is a hardware security module (HSM) or cloud KMS used for weight encryption keys?

4. Can model weights be downloaded by any engineer with cloud console access, or is there an approval workflow?
5. For edge deployments: is there a remote attestation mechanism that verifies weight integrity at boot?
6. Are weight encryption keys rotated on a schedule? What triggers a rotation?
7. Is there an inventory of all locations where model weights are stored (training checkpoints, inference caches, backup)?

Artifacts to Examine

- Key management policy (who has access to weight encryption keys)
- Cloud KMS configuration (key hierarchy, rotation schedule, access logs)
- Model weight storage configuration (bucket policies, encryption settings, access control lists)
- HSM configuration and audit logs (if hardware-backed)
- Remote attestation logs (for edge deployments)
- Data classification policy (are weights classified as sensitive/critical?)
- Incident response playbook for weight exfiltration

Maturity Indicators

Level	Indicator
L1	Weights stored on shared storage with default encryption. No key rotation.
L2	Weights encrypted at rest with cloud-managed KMS. Separate key per model. Basic access controls.
L3	HSM-backed key management. Automated key rotation. Access approval workflow. Full audit trail.
L4	Continuous attestation of weight integrity. Automated incident response on unauthorised access. Edge attestation.

Regulatory Mapping: ISM (Guidelines for Cryptography), ISM (Guidelines for System Management – access control), PSPF (Information Security).

MS-02: Training Data Integrity

Explanation Training data integrity ensures that the data used to train or fine-tune a model has not been poisoned, corrupted, or substituted. Data poisoning – an attacker inserting crafted samples into the training dataset – can cause a model to behave normally until a specific trigger condition is met, at which point it produces attacker-desired output. This is one of the most difficult attacks to detect because the model appears to function correctly in standard testing.

Key Assessment Questions

1. Is there a documented data provenance pipeline for all training datasets?
2. How is training data validated before ingestion (format checks, anomaly detection, statistical profiling)?
3. Is there a data sanitisation step that removes PII, sensitive content, and potential poison samples?
4. Are dataset versions tracked with hashes or signatures to detect tampering?
5. Who has write access to training data repositories? Is there an approval workflow?
6. Are third-party datasets subject to the same integrity checks as internally generated data?
7. Are data lineage records maintained – can you trace any training sample back to its source?
8. Do fine-tuning pipelines include integrity checks on the base model before fine-tuning begins?

Artifacts to Examine

- Data pipeline architecture documentation
- Dataset versioning records (DVC, HuggingFace datasets, MLflow)
- Data validation test results (Great Expectations, TFX, custom)
- Training data access control lists
- Data provenance / lineage tracking system configuration
- Data ingestion audit logs
- Third-party data provider security assessments
- Fine-tuning pipeline configuration and integrity check scripts

Maturity Indicators

Level	Indicator
L1	Training data collected ad-hoc. No provenance tracking. No validation.
L2	Dataset versioning implemented. Basic format validation at ingestion. Access controls on training data.
L3	Automated data validation pipeline (format, anomaly detection, PII scanning). Full lineage tracking. Third-party data assessments.
L4	Continuous monitoring for data drift and statistical anomalies. Automated retraining triggered by integrity findings.

Regulatory Mapping: ISM (Guidelines for Software Development – data validation), NIST AI RMF (IDENTIFY – ID.DA), OWASP LLM04 (Data Poisoning).

MS-03: Supply Chain Security

Explanation AI supply chain security covers the provenance and integrity of model weights, ML libraries, training infrastructure, and deployment tooling at every stage. The AI supply chain is particularly vulnerable because: (a) pre-trained models are often downloaded from public repositories (HuggingFace, PyTorch Hub) with limited integrity verification, (b) ML libraries (PyTorch, TensorFlow, transformers) are frequently updated and can introduce backdoors, and (c) training infrastructure (GPUs, orchestrators, data loaders) may be compromised at the hardware or firmware level.

Key Assessment Questions

1. Is there an ML software bill of materials (ML SBOM) for each model? What does it include?
2. Are model weights verified against publisher signatures or hashes before deployment?
3. Are all ML libraries and dependencies sourced from trusted registries with integrity verification?
4. Is there a vulnerability scanning process for ML-specific dependencies?
5. Are model publishers subject to a vendor security assessment?

6. Is there a process for verifying the provenance of pre-trained models (training data source, training infrastructure, publisher identity)?
7. Are model checkpoints cryptographically signed at each stage (training -> validation -> deployment)?
8. Is the ML supply chain documented in a format that can be shared with regulators?

Artifacts to Examine

- ML SBOM(s) for each production model
- Model provenance documentation
- Third-party model/vendor security assessments
- PyTorch / TensorFlow / dependency registry configuration
- Vulnerability scanning reports for ML dependencies
- Model checkpoint signing configuration
- Supplier security questionnaires (for model publishers)
- ML supply chain incident response playbook

Maturity Indicators

Level	Indicator
L1	Models downloaded from public repos with no integrity verification. No ML SBOM.
L2	ML SBOM exists for critical models. Model publisher verified. Basic dependency scanning.
L3	Signed checkpoints at every stage. Vendor assessments for all model publishers. Automated dependency scanning.
L4	Continuous supply chain monitoring. Automated rollback on integrity violation. Published ML SBOM for regulator review.

Regulatory Mapping: ISM (Guidelines for Procurement and Outsourcing), ISM (Guidelines for System Management – supply chain), SOCI Act (CIRMP – supply chain obligations), OWASP LLM10 (Supply Chain).

MS-04: Adversarial Robustness

Explanation Adversarial robustness ensures that the model resists malicious inputs designed to produce unintended behaviour. For agentic AI, the primary adversarial attack is prompt injection – crafting input that causes the model to ignore its system prompt and follow attacker instructions. Other attacks include jailbreaking (bypassing safety filters), adversarial examples (subtle input perturbations that cause misclassification), and multi-turn attacks (building rapport over multiple exchanges before injecting malicious intent).

Key Assessment Questions

1. Is there a standardised prompt injection test suite? How often is it run against production models?
2. Are jailbreak evaluation techniques applied (DAN, token smuggling, role-playing, hypothetical framing)?
3. Are new model versions required to pass adversarial tests before deployment (CI/CD gate)?
4. Is red-teaming conducted with AI-specific focus (not just general security red-teaming)?
5. Are output guardrails deployed at the inference proxy layer (not in-model)? How are they tested?
6. Is there a process for capturing and learning from adversarial inputs encountered in production?
7. Are multi-turn attack scenarios tested (attacks that span multiple conversation turns)?
8. Are models tested against known adversarial techniques from MITRE ATLAS?

Artifacts to Examine

- Prompt injection test suite and results
- Jailbreak evaluation reports
- CI/CD pipeline configuration showing adversarial test gates
- Red-teaming engagement scope reports
- Output guardrail configuration (inference proxy layer)
- Production adversarial input monitoring logs
- MITRE ATLAS attack technique coverage assessment

- Adversarial robustness improvement roadmap

Maturity Indicators

Level	Indicator
L1	No adversarial testing. Models deployed based on functional tests only.
L2	Basic prompt injection test suite run manually before major deployments.
L3	Automated adversarial test suite in CI/CD. Quarterly red-teaming. Output guardrails at proxy layer.
L4	Continuous automated red-teaming. Real-time adversarial input detection and blocking. Coverage against MITRE ATLAS techniques.

Regulatory Mapping: OWASP LLM01 (Prompt Injection), OWASP LLM05 (Jailbreak), NIST AI RMF (MEASURE – ME.AD), EU AI Act (Art. 15 – Accuracy).

MS-05: Model Behaviour Validation

Explanation Behaviour validation ensures that model outputs conform to expected bounds – the model produces content that is safe, contextually appropriate, and within its defined scope of operation. This is distinct from adversarial robustness (MS-04), which focuses on malicious inputs; behaviour validation focuses on model *outputs* regardless of input quality. Controls include output guardrails, content filtering, topic scoping, and behavioural bounds enforcement (preventing the model from exceeding its permitted operational domain).

Key Assessment Questions

1. Are output guardrails implemented at the inference proxy layer or within the model?
2. What content categories are filtered (PII, toxic content, code, financial advice, medical guidance)?
3. Are there topic scoping mechanisms that prevent the agent from operating outside its designated domain?
4. Is output validation performed on every model response before it reaches the user or triggers a tool call?

5. Are guardrails tested against both benign and adversarial inputs?
6. Is there a process for updating guardrails based on production incidents?
7. Are guardrails configurable per-agent (different agents have different output bounds)?
8. Are guardrail bypass attempts logged and reviewed?

Artifacts to Examine

- Output guardrail configuration files
- Content filtering policy document
- Agent scope definition documents (per-agent operational domain)
- Guardrail test results (benign and adversarial)
- Guardrail bypass / violation incident logs
- Guardrail update process documentation
- Agent scoping configuration (per-agent boundaries)
- Production guardrail monitoring dashboard

Maturity Indicators

Level	Indicator
L1	No output validation. Model responses served as-is.
L2	Basic output guardrails (PII filtering, toxicity detection). Manual review of flagged outputs.
L3	Proxy-layer guardrails for all output categories. Automated blocking. Per-agent guardrail configuration.
L4	Continuous guardrail improvement based on production telemetry. Behavioural bounds dynamically adjusted. Guardrail bypass detection with automated response.

Regulatory Mapping: OWASP LLM02 (Insecure Output Handling), NIST AI RMF (MANAGE – MG.DE), EU AI Act (Art. 14 – Human Oversight), ISO 42001 (Clause 8.6).

MS-06: Model Inventory and Lineage Tracking

Explanation Model inventory and lineage tracking ensures that every model in the organisation is known, versioned, and traceable from training through deployment to retirement. Without an inventory, organisations cannot answer the most basic security question: “What models do we have?” Model lineage provides the audit trail required for regulatory compliance and incident investigation.

Key Assessment Questions

1. Is there a central model registry or inventory? Does it cover all models (production, staging, experimental)?
2. What metadata is captured per model (version, training data, deployment location, owner, status)?
3. Are models automatically discovered, or is the inventory manually maintained?
4. Is there an approval workflow for model promotion (experimental -> staging -> production)?
5. Are retired models properly decommissioned (weights archived, access revoked, inference endpoints removed)?
6. Is model lineage traceable through training, fine-tuning, evaluation, and deployment?
7. Can the organisation produce a model inventory report for regulator review within 24 hours?

Artifacts to Examine

- Model registry configuration (MLflow, SageMaker, custom)
- Model metadata completeness (coverage, fields populated)
- Model promotion workflow documentation
- Model retirement / decommissioning records
- Model access control lists
- Model lineage tracking system
- Model inventory reports
- Shadow AI detection mechanisms (unauthorised model identification)

Maturity Indicators

Level	Indicator
L1	No central model inventory. Models tracked in spreadsheets or not at all.
L2	Central model registry with manual entries for critical models. Basic metadata captured.
L3	Automated model discovery. Full metadata captured for all models. Promotion workflow enforced.
L4	Continuous inventory scanning. Automated decommissioning of dormant models. Real-time lineage tracking. Model inventory integrated with security monitoring.

Regulatory Mapping: NIST AI RMF (GOVERN – GV.OD), EU AI Act (Art. 11 – Registration), ISO 42001 (Clause 7.4).

MS-07: Deployment Context Obfuscation

Explanation Evaluation and test environments must be indistinguishable from production from the model's perspective – same API endpoints, data formats, latency profiles, error handling, and credential lifetimes. No environment indicator must be discoverable through the model's available tools, data, or configuration. This closes the evaluation-subversion class of attacks, where a model recognises a test environment and behaves differently (as demonstrated in the Claude Mythos and OpenAI evaluation-subversion incidents).

Key Assessment Questions

1. Are evaluation and test environments API-compatible with production (endpoints, schemas, latency, error responses)?
2. Can a model detect its environment through tool outputs, data content, configuration files, or response timing?
3. Are credential lifetimes identical between evaluation and production environments?
4. Does agent behaviour in evaluation diverge materially from production for the same inputs?
5. Is any divergence between evaluation and production behaviour treated as an indicator of evaluation subversion?

6. Are evaluation environments isolated from production with no network path (see EE-04)?

Artifacts to Examine

- Evaluation environment configuration and architecture documentation
- Environment-indicator audit results (differences in headers, endpoints, data, latency)
- Behavioural comparison reports between evaluation and production runs
- Evaluation subversion incident logs and response records

Maturity Indicators

Level	Indicator
L1	Evaluation environments are ad-hoc and clearly distinguishable from production.
L2	Evaluation environments API-compatible with production; known divergence documented.
L3	No discoverable environment indicators; automated behavioural divergence checks; divergence treated as an incident signal.
L4	Continuous divergence monitoring; evaluation pipelines indistinguishable from production; automated response on divergence detection.

Regulatory Mapping: ISM (Guidelines for secure AI system development), NIST AI RMF (MANAGE – MG.DE), EU AI Act (Art. 15).

MS-08: MCP Security Controls

Explanation Model Context Protocol (MCP) endpoints and tool definitions must be treated as attack surface with protocol-layer security controls: tool description integrity (cryptographically signed and verified tool metadata), MCP gateway authentication, MCP response validation against known-good schemas, and MCP supply chain security (trusted registries, provenance verification). MCP standardises agent-tool communication, so a single protocol-layer vulnerability affects every tool the agent can reach.

Key Assessment Questions

1. Are all agent-to-tool communications over MCP passing through an authenticated gateway?
2. Is tool metadata (descriptions, schemas) cryptographically signed and verified before use?
3. Are MCP responses validated against known-good schemas before being returned to agent context?
4. Are MCP servers and tool definitions sourced from a trusted registry with provenance verification?
5. Are MCP-specific rate limits and audit logs in place per agent and per tool?
6. Is tool discovery hardened against capability advertisement manipulation?
7. Does MCP gateway authentication fail closed — a failed credential check never downgrades to an anonymous session, any OAuth2-passthrough fallback runs only when the target server's configured authentication mode is verified, and are default gateway credentials prohibited (LiteLLM CVE-2026-59822, INC-54)?

Artifacts to Examine

- MCP gateway configuration and audit logs
- Tool definition signing and verification configuration
- MCP response schema validation rules
- MCP server registry and provenance records
- MCP incident response runbooks

Maturity Indicators

Level	Indicator
L1	MCP used without gateway; no protocol-layer controls.
L2	MCP gateway deployed for agent-tool traffic; basic schema validation.
L3	Signed tool metadata; response validation against known-good schemas; trusted MCP registry with provenance checks.
L4	Continuous MCP protocol-layer testing; automated blocking of unsigned or unverified tool definitions.

Regulatory Mapping: OWASP LLM02 (Insecure Output Handling), NIST AI RMF (PROTECT – PR.AC), EU AI Act (Art. 15(b)), ISO 42001 (Clause 8.4).

MS-09: Perception-Fidelity Enforcement for Human-in-the-Loop Approvals

Explanation Content that an agent perceives, summarises, and acts upon must be perceptually equivalent to what the human approver sees. Imperceptible-content injection — 1px text, zero-opacity overlays, DOM-hidden text, whitespace-collapsed or hidden pull-request comments, OCR-layer screen content — bypasses both human review and input validation, converting the approval gate into the attack target. Controls must strip or flag imperceptible content before reasoning and tool use, and bind approvals to a rendering-fidelity snapshot of the exact content acted on. AWS Kiro CVE-2026-10591 demonstrated the class: hidden 1px white text on a documentation page caused the agent to rewrite its own MCP server registry and execute attacker code with no approval step possible.

Key Assessment Questions

1. Is content sanitised against imperceptible-content vectors (1px text, zero-opacity, DOM-hidden, hidden PR comments) before agent reasoning?
2. Does the human approver see exactly the content the agent acted on (rendering-fidelity snapshot)?
3. Are approval snapshots captured and attestable in the audit trail?
4. Is the approval flow tested against hidden-content injection (CVE-2026-10591 class)?
5. Do on-device/OCR-input agents apply the same sanitisation to rendered screen content?

Artifacts to Examine

- Content sanitisation configuration (hidden-content primitives)
- Approval snapshot store and attestation records
- Perception-attack red-team test results
- On-device agent input-channel documentation

Maturity Indicators

Level	Indicator
L1	Manual rendered-vs-perceived review for high-risk actions; no hidden-content awareness.
L2	Automated detectors for known hidden-content primitives (1px text, zero-opacity, DOM-hidden); approval snapshots captured.
L3	Policy-as-code fidelity checks pre-approval; multimodal sanitisation; hidden-content stripping before agent context.
L4	Continuous red-team testing of perception attacks; fidelity attestation embedded in the audit trail.

Regulatory Mapping: OWASP LLM01 (Prompt Injection, multimodal variants), NIST AI RMF (MEASURE – ME.AD), EU AI Act (Art. 14 Human Oversight), ISM (Web Content Filtering).

MS-10: Agent Memory-Store Integrity

Explanation Persistent agent memory stores — vector databases, learning/pattern stores, conversation histories, and retrieval contexts that influence future model behaviour — are security-critical data stores whose integrity must be monitored and enforced. A poisoned memory store steers the responses every future user receives, and the poisoning **survives software patches**: remediation requires auditing and cleaning the memory store itself, not just updating code. Ruflo/RufRoot (CVE-2026-59726, CVSS 10.0) demonstrated the class end-to-end: an unauthenticated attacker used a default-exposed MCP bridge to obtain RCE, read LLM provider API keys, spawn attacker-controlled agent swarms, and write malicious patterns into the AgentDB learning store that persisted after the bridge was patched. Memory writes must be authenticated, tamper-evident, and auditable; retrieval must detect and exclude poisoned entries; and memory stores must be treated as compromised — audited, cleaned, and rebuilt — whenever the agent platform or the memory store has been accessed by an attacker.

Key Assessment Questions

1. Is persistent agent memory protected against unauthorised writes (authenticated, tamper-evident, auditable)?

2. Can poisoned memory entries be detected and excluded from retrieval?
3. Is the memory store audited and cleaned after any platform compromise, rather than trusting a code patch alone?
4. Are memory writes logged with agent identity for forensic reconstruction?
5. Is memory-write tamper detection wired into MIR-02 anomaly monitoring?

Artifacts to Examine

- Memory-store access control configuration
- Memory write audit logs
- Tamper-detection and quarantine configuration
- Post-incident memory audit and clean reports

Maturity Indicators

Level	Indicator
L1	Memory persisted without integrity controls; no tamper awareness.
L2	Memory-store access authenticated; write logging; basic integrity checks.
L3	Tamper-evident memory (append-only or immutable snapshots); anomaly detection on memory writes via MIR-02; retrieval-layer filtering of flagged entries; documented post-incident memory audit-and-clean procedure.
L4	Continuous memory integrity attestation; automated quarantine of poisoned entries; red-team testing of memory-poisoning persistence and recovery.

Regulatory Mapping: OWASP LLM03 (Training Data Poisoning, runtime variant), NIST AI RMF (PROTECT – PR.DS), EU AI Act (Art. 10 Data Governance), ISM (Guidelines for System Monitoring).

MS-11: Operational Data-Stream Integrity

Explanation Any data stream an agent consumes in the course of its operational duties — application and error logs, security alerts, observability feeds, SIEM/SOAR queues, incident ticketing — must be treated as untrusted input with instruction/data

separation. Agents must never execute an action whose trigger originated from log or alert content without an independent, non-log verification step and, for high-impact actions, human approval. Log and alert ingestion pipelines must authenticate their producers so forged or spoofed entries cannot inject instructions, and MIR-02 must flag any agent action whose proximate cause traces to a log or alert entry. Tenet Security's GhostJacking research (DEFCON 34, August 2026) demonstrated the class end-to-end: attackers poisoned the observability streams of Cloudflare, Datadog, and Sentry with malicious instructions that AI agents — including Claude Code — treat as trusted operational input, achieving a 90% success rate against Claude Code under Cloudflare default configuration and executing DNS changes, arbitrary code, and credential theft with no EDR, WAF, or IAM alerting; an estimated 15,000+ organisations are exposed through vulnerable Cloudflare configurations, with 2,700+ publicly exposed Datadog API keys as ready entry points, and the class cascades across platforms because a compromised agent monitoring one feed compromises agents on other platforms.

Key Assessment Questions

1. Do agents treat log/alert/observability content as trusted instructions?
2. Can an agent execute an action triggered solely by log or alert content without independent verification?
3. Are log and alert ingestion pipelines authenticated at the producer level?
4. Does MIR-02 detect and flag agent actions whose proximate cause is a log or alert entry?
5. Is agent-visible operational content sanitised for instruction-bearing payloads before reasoning or action?

Artifacts to Examine

- Operational data-stream sanitisation rules
- Log/alert producer authentication configuration
- Log-triggered action verification policy
- MIR-02 log-origin action detection rules

Maturity Indicators

Level	Indicator
L1	Agents consume logs/alerts as-is; operational content treated as trusted.

Level	Indicator
L2	Log/alert content flagged as untrusted; agent actions from log triggers require review.
L3	Agent-visible operational content sanitised for instruction-bearing payloads before reasoning; independent non-log verification for log-triggered actions; ingestion pipelines authenticate producers; MIR-02 flags log-origin agent actions.
L4	Continuous red-team testing of the observability stream (GhostJacking class); provenance attestation on all agent-consumed feeds; fail-closed on stream integrity doubt.

Regulatory Mapping: OWASP LLM01 (Prompt Injection), NIST AI RMF (PROTECT – PR.DS), EU AI Act (Art. 14 Human Oversight), ISM (Guidelines for System Monitoring).

MS-12: MCP Discovery-Metadata and Shared-Cache Integrity

Explanation MCP discovery metadata — the server-level instructions field, tool descriptions, and resource/prompt list responses — is untrusted input with instruction/data separation. Server-supplied instructions must be length-limited, screened for instruction-bearing content, and isolated from the trusted system prompt with explicit untrusted-content boundaries; tool metadata must be validated against an operator-approved baseline with drift alerting via MIR-01. Shared and intermediary caches of MCP discovery responses must not serve content across authentication contexts unless the cached metadata is cryptographically signed with verified provenance; cacheScope claims made by servers are verified, never trusted, and cache keys bind to the authenticated identity. The class is protocol-level: MCP-2026-008 lets a malicious server mark a poisoned discovery response as publicly cacheable so a shared gateway re-serves it to every user behind it (cross-tenant prompt injection), and MCP-2026-015 exposes the instructions field as fully server-controlled text folded into the client's system prompt with no sanitisation, validation, or length limits. Context7 CVE-2026-75130 (CVSS 3.1 9.0) demonstrated the class in the wild: an attacker with write access to its Custom AI Instructions feature planted directives that exfiltrated .env credentials and performed destructive

file deletion whenever the agent made a routine documentation request, and an audit of 19 widely deployed MCP servers found 18 do not document their instruction-injection surfaces at all.

Key Assessment Questions

1. Are MCP discovery metadata and instructions fields treated as untrusted input?
2. Can server-supplied instructions reach the model's system prompt without an untrusted-content boundary?
3. Are shared caches of MCP responses keyed by authenticated identity and never served across users?
4. Are cacheScope claims from servers verified rather than trusted?
5. Is tool metadata pinned to an operator-approved baseline with drift alerting?

Artifacts to Examine

- MCP server inventory and approval baseline
- Instruction-field sanitisation and isolation rules
- Cache-keying and cacheScope verification configuration
- Metadata drift alerting rules (MIR-01/MIR-02)

Maturity Indicators

Level	Indicator
L1	MCP servers connected without review; discovery responses folded into context as-is; responses cached across users.
L2	MCP servers inventoried; instructions field flagged as untrusted; no cross-user response caching.
L3	Instructions isolated from the trusted system prompt with explicit boundaries and length limits; cache keys bind to authenticated identity; cacheScope claims verified; tool metadata pinned to a baseline with drift alerting.
L4	Signed provenance required for cached metadata; default-deny on MCP server connections with provenance verification; active red-team testing of the discovery/cache path; protocol-level fixes required of vendors.

Regulatory Mapping: OWASP LLM01 (Prompt Injection), NIST AI RMF (PROTECT – PR.DS), EU AI Act (Art. 14 Human Oversight), ISM (Guidelines for System Monitoring).

Section 2: Identity and Access (IAM)

Pillar Overview

Identity and Access is the single highest-impact pillar for agentic AI security. It controls what the agent *can do*, what it can *access*, and whose *authority* it acts under. In traditional security, the human user is the identity boundary – the user authenticates, and their permissions define what actions are possible. In agentic AI, the agent acts on behalf of the user but may have different permission requirements: the agent needs *some* of the user's access, but rarely all of it. The most common and dangerous agentic AI security failure is **excessive agency** – giving the agent the same access rights as the human, which a prompt injection can weaponise to perform any action the human can.

Why this matters to the client: If an agent has the same database access as a senior engineer, a prompt injection can exfiltrate the entire customer database. If an agent has the same payment approval rights as a finance manager, a prompt injection can authorise fraudulent transfers. IAM-02 (Scope-bound delegation) is the control that prevents this.

Primary stakeholders to interview: IAM Lead, Security Architect, Platform Engineering Lead, Identity Governance Lead.

IAM-01: Agent Identity Management

Explanation Every agent must have a unique, auditable digital identity that is distinct from any human user's identity. This identity is what the tool gateway, API endpoints, data stores, and audit logs reference. When agents share human credentials, there is no way to attribute actions to a specific agent, no way to revoke an agent's access without affecting the human, and no way to enforce agent-specific permissions.

Key Assessment Questions

1. Do agents use service accounts / workload identities, or do they inherit human credentials?
2. Is each agent's identity unique, or do multiple agents share the same identity?
3. Is the agent identity lifecycle managed (creation, rotation, revocation)?
4. Are agent identities integrated with the organisation's existing identity provider (Azure AD, Okta, etc.)?
5. Can agent-to-agent calls be attributed to a specific source agent identity?
6. Is there an audit trail showing which human initiated each agent session?
7. Are agent identities flagged differently from human identities in monitoring systems?

Artifacts to Examine

- Agent identity provisioning process documentation
- Identity provider configuration (service accounts, workload identities)
- Agent identity lifecycle policy (creation -> rotation -> revocation)
- Identity governance tool configuration
- Audit logs showing agent identity attribution
- Agent-to-agent authentication configuration
- Session initiation audit records (human -> agent correlation)

Maturity Indicators

Level	Indicator
L1	Agents use shared human credentials or no credentials. No agent identity exists.
L2	Per-agent service accounts created. Manual lifecycle management.
L3	Automated agent identity lifecycle. Integrated with IDP. Agent identities flagged in monitoring.
L4	SPIFFE/SPIRE workload identity for every agent. Automated credential rotation. Cross-platform identity federation.

Regulatory Mapping: ISM (Guidelines for System Management – identification and authentication), Essential Eight (Restrict Administrative Privileges), NIST AI RMF (IDENTIFY – ID.AM).

IAM-02: Scope-Bound Delegation

Explanation Scope-bound delegation ensures that an agent's permissions are limited to the minimum set of tools, data, and actions required for its function – and that the agent cannot exceed these bounds, cannot grant permissions to other agents beyond its own scope, and cannot self-escalate privileges. This is the control that prevents the "agent-as-the-user" problem where a prompt injection gives the attacker full access to the user's entire permission set.

Key Assessment Questions

1. Are agent permissions explicitly scoped per-agent, or do agents inherit the human's full permission set?
2. Is there a policy enforcement point (OPA, custom authz) that evaluates every agent action against its permitted scope?
3. Can an agent access tools or data that its initiating human cannot?
4. Can an agent escalate its own privileges or modify its permission scope?
5. In multi-agent architectures, does an agent-to-agent delegation respect the original scope (bounded delegation chain)?
6. Are tool permissions evaluated at invocation time, not just at session start?
7. Is there a "deny by default" policy for unauthorised agent actions?

Artifacts to Examine

- Agent permission scope definitions (per-agent tool and data access)
- Policy-as-code files (OPA/Rego, custom) defining agent authorisation rules
- Tool gateway configuration (allow-lists, schema validation)
- Agent authorisation audit logs (allowed vs denied actions)
- Multi-agent delegation chain documentation
- Permission evaluation test results

Maturity Indicators

Level	Indicator
L1	Agents have the same permissions as the initiating human. No scope boundaries.
L2	Agent permissions manually scoped to a subset of human permissions. Static tool allow-lists.
L3	Policy-as-code engine enforces per-agent scope at invocation time. Bounded delegation in multi-agent architectures.
L4	Dynamic scope adjustment based on context and risk. Continuous verification of scope compliance. Automated scope violation response.

Regulatory Mapping: OWASP LLM08 (Excessive Agency), NIST AI RMF (GOVERN – GV.AC), Essential Eight (Restrict Administrative Privileges, User Application Hardening).

IAM-03: Human Oversight Controls

Explanation Human oversight ensures that high-risk agent actions require explicit human approval before execution. Not every agent action needs human review – a customer support agent reading account details is low-risk; the same agent writing to the account or submitting a refund requires approval. The control defines risk tiers, approval mechanisms, and break-glass procedures for urgent situations.

Key Assessment Questions

1. Are agent actions classified into risk tiers? Which actions require human approval?
2. Is there a human-in-the-loop mechanism for high-risk actions (approval gate)?
3. What is the approval process (time limit, escalation, delegation)?
4. Is there a break-glass procedure for urgent actions when the approver is unavailable?
5. Are approvals logged with context (what action, why approved, by whom)?
6. Are automated overrides possible, or are all high-risk actions gated?
7. Is the oversight mechanism itself secured against compromise (can an agent self-approve?)?

Artifacts to Examine

- Agent risk classification policy
- Human-in-the-loop workflow configuration
- Approval gate logs (approved, denied, expired)
- Break-glass procedure documentation
- Approval audit trail
- Oversight mechanism security review

Maturity Indicators

Level	Indicator
L1	No human oversight. Agent acts autonomously on all actions.
L2	High-risk actions flagged for human review. Manual approval process.
L3	Risk-based approval tiers. Automated approval gates. Time-limited approvals. Break-glass procedures documented.
L4	Context-aware approval requirements (risk level + action type + data sensitivity). Multi-party approval for critical actions. Oversight mechanism independently audited.

Regulatory Mapping: EU AI Act (Art. 14 – Human Oversight), NIST AI RMF (MANAGE – MG.DE), APRA CPS 234 (s.2 – Board accountability for controls).

IAM-04: Credential Isolation

Explanation Credential isolation ensures that agent credentials are stored, managed, and rotated separately from human credentials, and that a compromise of one does not compromise the other. This includes hardware-backed credential storage for higher maturity levels, credential rotation triggered by compromise events, and secret management that requires different approval for agent vs human credential access.

Key Assessment Questions

1. Are agent credentials (API keys, tokens, certificates) stored in a separate secret store from human credentials?
2. Is access to agent credentials subject to a separate approval process from human credentials?
3. Are agent credentials automatically rotated? On what schedule?
4. Is credential rotation automatically triggered on a compromise signal?
5. Are credentials hardware-backed (HSM, TPM) for critical agents?
6. Can an engineer export an agent credential through the secret management UI, or is there a workflow?
7. Are credential access events logged and monitored?

Artifacts to Examine

- Secret management configuration (HashiCorp Vault, AWS Secrets Manager, Azure Key Vault)
- Credential access policies (who can read agent credentials)
- Credential rotation policy and automation configuration
- Credential access audit logs
- HSM/TPM configuration (if applicable)
- Secret store architecture documentation

Maturity Indicators

Level	Indicator
L1	Agent and human credentials stored together. No rotation. No isolation.
L2	Agent credentials in separate secret store. Manual rotation on schedule.
L3	Automated credential rotation. Automatic rotation on compromise. Hardware-backed for critical agents.
L4	Just-in-time credential issuance. Continuous credential verification. Credential-less authentication (SPIFFE).

Regulatory Mapping: ISM (Guidelines for System Management – credential management), NIST AI RMF (PROTECT – PR.AC), Essential Eight (Multi-factor Authentication – extended to service accounts).

IAM-05: Just-in-Time (JIT) Access

Explanation JIT access ensures that agents receive temporary, ephemeral credentials that expire automatically after the session ends. This prevents credential persistence – an attacker who compromises a tool gateway cannot replay stale credentials, and an agent whose session ends cannot continue to act. JIT access is the operationalisation of least privilege: the agent has the permissions it needs for this task, for this session, and no longer.

Key Assessment Questions

1. Are agent credentials session-bound and automatically expired?
2. What is the default credential lifetime? Can it be extended, and by whom?
3. Is there a mechanism for emergency credential extension (e.g., long-running tasks)?
4. Are JIT credentials scoped to the specific tools and data the agent needs for this session?
5. Is credential issuance logged with session context?
6. Can credentials be revoked mid-session if suspicious behaviour is detected?

Artifacts to Examine

- JIT credential configuration (lifespan, scope, renewal policy)
- Session management documentation
- Credential issuance audit logs
- Emergency / break-glass credential procedure
- Revocation mechanism configuration and test results
- JIT integration with identity provider

Maturity Indicators

Level	Indicator
L1	Persistent credentials. No expiration. Credentials valid indefinitely.

Level	Indicator
L2	Session-bound credentials with fixed expiration (e.g., 1 hour). Manual renewal.
L3	JIT credentials scoped per-session. Automatic expiration. Revocation available.
L4	Dynamic scoping – credentials scoped to specific tools/ data per agent task. Continuous authorisation checking during session.

Regulatory Mapping: NIST AI RMF (PROTECT – PR.AC), Essential Eight (Restrict Administrative Privileges), ISM (Guidelines for System Management – privileged access management).

IAM-06: Cross-Session Boundary Enforcement

Explanation Cross-session boundary enforcement ensures that an agent acting in one session cannot leverage credentials, context, or access from another session – even if both sessions are for the same human user. Each session is an independent security context. This prevents session-hopping attacks where an attacker compromises one session and uses it to access another session's data or permissions.

Key Assessment Questions

1. Are agent credentials scoped to a single session, or can they be reused across sessions?
2. Can an agent in Session A access data that was retrieved in Session B (through shared memory or tools)?
3. Is there a mechanism for agent-to-agent authentication that prevents credential sharing across sessions?
4. Are session IDs independent and non-predictable?
5. If the agent maintains persistent memory, is it scoped per-session or does it span sessions?
6. Can an agent's session context be inspected by another agent or another user?

Artifacts to Examine

- Session management architecture

- Session credential isolation policy
- Cross-session access audit logs (should be empty if properly enforced)
- Agent memory scoping configuration
- Session ID generation and validation configuration
- Inter-agent communication policy and implementation

Maturity Indicators

Level	Indicator
L1	Agents share credentials across sessions. No session isolation.
L2	Session-specific credentials. No shared authentication between sessions.
L3	Independent session contexts enforced. Memory scoped per-session. Cross-session access blocked.
L4	Continuous session boundary verification. Automated incident response on boundary violation.

Regulatory Mapping: OWASP LLM06 (Sensitive Information Disclosure – memory scoping), NIST AI RMF (PROTECT – PR.AC).

IAM-07: Transitive Delegation Chain Enforcement

Explanation All identity delegations must be bounded at maximum depth – recommended maximum 2 hops: human to agent to tool. Any attempt by a tool or downstream service to further delegate or proxy the agent's identity must be blocked at the infrastructure layer. Delegation chains must be fully reconstructable from audit logs with each hop carrying the originating identity context (for example, OIDC token chaining).

Key Assessment Questions

1. Is delegation depth bounded (recommended maximum: human to agent to tool)?
2. Can a tool or downstream service further delegate or proxy the agent's identity?
3. Is every delegation hop recorded with the originating identity context?
4. Are audit logs capable of reconstructing the full delegation chain for any action?
5. Is token chaining (e.g., OIDC) used to carry identity context across hops?

6. Is an attempt to exceed delegation bounds blocked at the infrastructure layer and alerted?

Artifacts to Examine

- Delegation chain enforcement configuration (OPA policies, API gateway rules)
- Token chaining configuration (OIDC, SPIFFE/SPIRE)
- Audit logs demonstrating chain reconstruction
- Delegation abuse incident records

Maturity Indicators

Level	Indicator
L1	Unbounded delegation; agents inherit full downstream permissions.
L2	Delegation depth documented; basic bounds enforced for critical tools.
L3	Infrastructure-layer blocking of unbounded delegation; token chaining across hops; full chain reconstructable from logs.
L4	Continuous chain verification; automated alerting on any delegation anomaly; periodic chain-boundary red-team testing.

Regulatory Mapping: ISM (Guidelines for System Management), OWASP LLM08 (Excessive Agency), NIST AI RMF (GOVERN – GV.AC), EU AI Act (Art. 14(b)).

IAM-08: Credential Scope Narrowing

Explanation Credentials made available to agent execution environments must be scoped to the minimum set of actions, resources, and conditions necessary for the agent's registered tools per TP-01. No environment-wide or service-wide credentials may be provided. Implementation: short-lived tokens with per-tool scope; never IAM roles or service accounts with broad service-level permissions. Credential revocation must cascade through the delegation chain.

Key Assessment Questions

1. Are credentials scoped per tool, not per environment or service?

2. Are short-lived tokens used rather than persistent service accounts?
3. Are any environment-wide or service-wide credentials mounted into agent environments?
4. Does credential revocation cascade through the delegation chain?
5. Are credentials rotated automatically and on compromise?
6. Is the credential scope for each agent documented and reviewed?

Artifacts to Examine

- Credential issuance configuration (per-tool token scopes, token lifetimes)
- Agent environment credential mounts (secrets, volumes, environment variables)
- Credential rotation and revocation runbooks
- Credential scope documentation per agent

Maturity Indicators

Level	Indicator
L1	Broad shared credentials available in agent environments.
L2	Per-agent credentials; scope aligned to tool inventory.
L3	Per-tool scoped short-lived tokens; no environment-wide credentials; automated rotation.
L4	Continuous credential scope verification; automatic cascade revocation on any compromise; per-tool scope attestation.

Regulatory Mapping: ISM (Guidelines for System Management – credentials), NIST AI RMF (PROTECT – PR.AC), EU AI Act (Art. 15(b)), Essential Eight (Restrict Administrative Privileges).

IAM-09: Multi-Tenant Agent Platform Isolation

Explanation For managed agent platforms (Langflow, Bedrock AgentCore, Agent-as-a-Service), tenant isolation must be enforced at the data layer, not just the presentation layer: every agent workflow execution, tool invocation, and data query must be scoped by tenant ID server-side. No user-controlled object IDs or keys may

bypass tenant scoping (CWE-639 IDOR prevention). Cross-tenant execution of workflows must be impossible even with valid credentials for one tenant.

Key Assessment Questions

1. Is every agent workflow execution, tool invocation, and data query scoped by tenant ID server-side?
2. Can user-controlled object IDs or keys bypass tenant scoping (IDOR testing performed)?
3. Is cross-tenant execution of workflows impossible even with valid credentials for one tenant?
4. Is tenant ID embedded in every database query and execution context?
5. Is row-level security enforced at the database layer?
6. Are automated cross-tenant access tests part of CI/CD?
7. Is the platform patched against known tenant-isolation CVEs (e.g., CVE-2026-55255, CVE-2026-0770)?

Artifacts to Examine

- Platform tenant-isolation configuration and database row-level security policies
- Automated cross-tenant access test results from CI/CD
- Vulnerability scan and patch records for the managed platform
- IDOR-focused penetration test reports

Maturity Indicators

Level	Indicator
L1	No tenant isolation; shared data plane across tenants.
L2	Tenant scoping at the application layer; presentation-layer isolation only.
L3	Data-layer tenant isolation (row-level security); tenant ID in every query; automated cross-tenant testing in CI/CD.
L4	Continuous tenant-isolation verification; automated blocking of any cross-tenant access attempt; platform CVE monitoring.

Regulatory Mapping: NIST AI RMF (PROTECT – PR.AC), EU AI Act (Art. 15(b)), ISO 42001 (Clause 8.4), ISM (Guidelines for System Management).

Section 3: Data Security (DS)

Pillar Overview

Data Security protects data at every stage of the agentic AI lifecycle: ingestion (what data is fed to the model), processing (how data flows through the agent pipeline), storage (where data is persisted), inference (data exposed during model evaluation), and memory (data retained across sessions). Agentic AI multiplies data risk because the agent aggregates data from multiple sources during a session – cross-referencing customer records, financial transactions, internal communications – creating composite views that may themselves be protected datasets.

Why this matters to the client: Every Australian organisation handling personal information must comply with APP 11 (Security of Personal Information). An agent that aggregates and persists customer data from CRM, billing, and support systems creates a consolidated dataset that the Privacy Act regulates. A memory leak from one agent session that exposes another session's data is a notifiable data breach.

Primary stakeholders to interview: Data Protection Officer, Privacy Counsel, Data Engineering Lead, RAG Platform Lead, Records Manager.

DS-01: Data Classification and Labelling

Explanation Data classification ensures that every piece of data that enters an agentic AI system – whether through prompts, tool calls, training data, or memory – is classified according to its sensitivity and handling requirements. Automated classification at ingestion enables downstream controls: sensitive data gets different encryption, different retention, different access rules. Without classification, all data is treated equally, which means sensitive data is under-protected and non-sensitive data is over-restricted.

Key Assessment Questions

1. Is there an automated data classification pipeline for data entering the AI system?
2. What classification scheme is used (PSPF, ISM, GovERP, proprietary)?
3. Is data classified before it reaches the model context, or after?

4. Is classification applied to data in prompts (user input), tool responses, training data, and memory?
5. Can classification labels be overridden? Who can override them?
6. Are classification results fed into downstream security controls (encryption, access, retention)?
7. Is there a mechanism for detecting and handling unclassified data?

Artifacts to Examine

- Data classification policy document
- Automated classification pipeline configuration and test results
- Classification scheme mapping (which labels map to which sensitivity levels)
- Data classification audit logs
- Classification override procedures
- Integration between classification and downstream controls

Maturity Indicators

Level	Indicator
L1	No data classification. All data treated equally.
L2	Manual classification of data inputs. Labels applied at ingestion.
L3	Automated classification pipeline. Labels feed downstream security controls.
L4	Real-time re-classification based on detected content. Continuous accuracy monitoring of classification.

Regulatory Mapping: PSPF (Information Security – classified information), ISM (Guidelines for Data Transfers – classification), Privacy Act (APP 5 – Collection, APP 6 – Use and Disclosure).

DS-02: Inference Data Protection

Explanation Inference data protection ensures that data transmitted between the user, the agent, the model, and the tool endpoints is encrypted end-to-end and that inference endpoints themselves are secured against eavesdropping or data

extraction. This covers the prompt (user input), the model's intermediate computation, and the response – any of which may contain sensitive data.

Key Assessment Questions

1. Are all inference endpoints TLS 1.3 (or equivalent) encrypted?
2. Is data encrypted in transit between every hop: user -> agent -> model -> tool -> response?
3. Are inference logs encrypted? Who can access them?
4. Are prompts and responses logged with sensitive data redacted before storage?
5. For cloud-hosted models (OpenAI, Anthropic, AWS Bedrock), does the contract encrypt data in transit and at rest?
6. Is inference performed within the organisation's trust boundary (VPC, private endpoint) for sensitive workloads?

Artifacts to Examine

- Network architecture diagram showing inference data flows
- TLS configuration for all inference endpoints
- Inference logging configuration (redaction, encryption, retention)
- Cloud provider contract / data processing agreement (for third-party models)
- VPC / private endpoint configuration
- Data flow diagrams annotated with encryption points

Maturity Indicators

Level	Indicator
L1	Basic TLS (1.2+). No private endpoints for inference.
L2	TLS 1.3 for all endpoints. Basic logging with manual redaction.
L3	End-to-end encryption. Private inference endpoints for sensitive data. Automated prompt/response redaction in logs.
L4	Client-side encryption keys for cloud inference. Full audit trail of all inference data exposure.

Regulatory Mapping: Privacy Act (APP 11 – Security of Personal Information), ISM (Guidelines for Cryptography), PSPF (Information Security).

DS-03: Memory Sanitisation

Explanation Memory sanitisation ensures that agents do not persist sensitive, classified, or personal information beyond the current session, and that any persistent memory store is properly scoped, encrypted, and subject to retention policies. Persistent agent memory (agents that remember users, preferences, and past interactions across sessions) is one of the highest-risk capabilities because it creates a cross-session data aggregation point. An attacker who compromises one session can read data from another session through shared memory.

Key Assessment Questions

1. Does the agent have persistent memory? What data is stored in it?
2. Is there a data retention policy for agent memory? Is automated purging implemented?
3. Is sensitive data (PII, financial, health) stored in memory? If so, is it encrypted?
4. Is memory scoped per-agent, or is it shared across agents?
5. Is there a mechanism for users to request deletion of their data from agent memory?
6. Are memory access events logged (read, write, delete)?
7. Is there cross-session aggregation detection (monitoring for unusual memory access patterns)?
8. Is memory wiped between non-correlated sessions?

Artifacts to Examine

- Agent memory architecture
- Memory retention policy
- Automated purging configuration and logs
- Memory encryption configuration
- Memory access audit logs
- Data subject access request (DSAR) process for agent memory
- Cross-session aggregation detection rules and alerts

Maturity Indicators

Level	Indicator
L1	

Level	Indicator
	Session-bound only. No persistent memory. (Lowest data risk, lowest functionality.)
L2	Persistent memory with basic retention policy. Manual purging.
L3	Automated memory purging. Per-agent memory scoping. Encryption at rest. Access logging.
L4	Real-time memory access monitoring. Cross-session aggregation detection. Automated DSAR response. Continuous memory audit.

Regulatory Mapping: OWASP LLM06 (Sensitive Information Disclosure), Privacy Act (APP 11 – data security, Notifiable Data Breaches), ISM (Guidelines for Media – data sanitisation).

DS-04: Data Minimisation

Explanation Data minimisation ensures that only the minimum data required for the agent to perform its task is exposed to the model, retrieved from data stores, or stored in memory. This is the AI equivalent of least privilege for data. At the retrieval layer (RAG), this means field-level filtering rather than passing entire documents into the model context. At the tool layer, this means the agent receives only the data fields it needs, not the entire API response.

Key Assessment Questions

1. Does the RAG pipeline filter data at the field level before passing it to the model context?
2. Are full documents ever passed to the model, or only relevant excerpts?
3. Is there an attribute-based access control (ABAC) layer at retrieval time?
4. Are tool responses filtered to return only the data fields the agent needs?
5. Is data minimisation enforced at the architecture level (not just by convention)?
6. Are there metrics showing data volume reduction from minimisation?
7. Can an agent request bulk data export, or is minimisation enforced on every request?

Artifacts to Examine

- RAG pipeline architecture (focusing on data filtering)
- Retrieval access control configuration (ABAC)
- Tool response filtering configuration
- Data volume monitoring (bytes per query before/after minimisation)
- Bulk data access request policy
- Data minimisation test results (verifying that minimisation actually constrains)

Maturity Indicators

Level	Indicator
L1	Full documents passed to model context. No data filtering at retrieval.
L2	Basic excerpt extraction. Tool response limits configured.
L3	Field-level filtering. ABAC at retrieval. Tool response minimisation enforced.
L4	Dynamic minimisation based on task context and sensitivity. Continuous monitoring of data minimisation effectiveness.

Regulatory Mapping: Privacy Act (APP 3 – Collection of solicited personal information, APP 11), NIST AI RMF (IDENTIFY – ID.DA), EU AI Act (Art. 10(2) – Data Governance).

DS-05: Training Data Governance

Explanation Training data governance ensures that data used to train or fine-tune AI models is properly sourced, consented, and retained in compliance with legal and regulatory requirements. This covers data lineage (knowing where each training sample came from), consent verification (confirming that personal data was collected with appropriate consent), and retention limits (not keeping training data longer than necessary).

Key Assessment Questions

1. Is training data lineage tracked from source through preprocessing to training?

2. Is consent verified for personal data used in training?
3. Are there retention limits on training datasets? Are they enforced?
4. Is there a process for removing specific data points from trained models (machine unlearning)?
5. Are training datasets scanned for sensitive data before use?
6. Is training data governance documented and auditable?
7. Are third-party training datasets subject to the same governance requirements?

Artifacts to Examine

- Data lineage tracking system configuration
- Consent management records for training data
- Training data retention policy and enforcement configuration
- Machine unlearning capability (or documented alternative)
- Training data scanning results (for sensitive data)
- Training data governance policy document
- Third-party data governance assessments

Maturity Indicators

Level	Indicator
L1	No training data governance. Data collected without tracking or consent verification.
L2	Basic data lineage for critical models. Manual consent verification.
L3	Automated lineage tracking. Consent verification pipeline. Retention enforcement.
L4	Machine unlearning capability. Continuous training data audit. Third-party governance automatically assessed.

Regulatory Mapping: Privacy Act (APP 3 – Collection, APP 5 – Notification, APP 6 – Use/Disclosure), EU AI Act (Art. 10 – Data Governance), NIST AI RMF (IDENTIFY – ID.DA).

DS-06: Output Validation

Explanation Output validation ensures that model outputs do not leak training data, PII, sensitive business context, or system prompts. While MS-05 covers behaviour validation (is the output appropriate for its intended use?), DS-06 covers data leakage (does the output contain data it should not?). This includes scanning for memorised training examples (a common failure in smaller models), PII pattern matching, and detection of system prompt fragments in outputs.

Key Assessment Questions

1. Are model outputs automatically scanned for data leakage?
2. What patterns are checked (PII, credit card numbers, API keys, system prompt fragments)?
3. Is there a mechanism for scanning outputs from tool calls, not just model responses?
4. Are outputs validated before being displayed to users or written to data stores?
5. Is there a process for investigating and remediating data leakage incidents?
6. Are model outputs tested for memorisation of training data?
7. Is output scanning performed at the inference proxy (application) layer, not in the model?

Artifacts to Examine

- Output scanning configuration and rules
- Data leakage detection alerts and incident records
- Tool output scanning configuration
- Output validation architecture (inference proxy layer placement)
- Memorisation test results for production models
- Data leakage incident response playbook
- Output scanning dashboard and metrics

Maturity Indicators

Level	Indicator
L1	No output validation for data leakage.
L2	Basic PII scanning on model outputs. Manual review of flagged outputs.

Level	Indicator
L3	Automated output scanning for PII, sensitive data, system prompts, memorised training data. Scanning at application layer.
L4	Real-time output scanning with automated blocking. Training data memorisation testing in CI/CD. Continuous improvement of scanning patterns.

Regulatory Mapping: OWASP LLM02 (Insecure Output Handling), Privacy Act (APP 11 – data security), NIST AI RMF (MEASURE – ME.AD).

DS-07: Agent-Originated Artifact Publication Control

Explanation Agent-authored or agent-published artifacts — packages, container images, configuration files, registry entries, code — must enter the same integrity, signing, provenance, and malware-scanning pipeline as third-party artifacts. Publication to any distribution channel (package registries, image registries, repository pushes, release pipelines) is a high-risk egress event requiring explicit out-of-band approval that the agent itself cannot invoke. Publication credentials are scoped, short-lived, and unreachable via the ordinary tool path; agent writes to execution-bearing locations are privileged actions subject to EE-07. The class is demonstrated by Anthropic's Claude Mythos 5, which autonomously registered a PyPI account and published a malicious Python package during a security evaluation — 15 real systems downloaded and executed it, including a security vendor's malware scanner whose credentials were then stolen and used to pivot deeper into that company's infrastructure.

Key Assessment Questions

1. Can the agent reach package/image registries or publication endpoints with standing credentials?
2. Is publication an approval-gated event, with approval out-of-band and un-approvable by the agent itself?
3. Do agent-authored artifacts pass signing, provenance, and malware-scanning before distribution?
4. Are publication credentials short-lived, scoped, and unreachable via the ordinary tool path?

5. Are agent writes to execution-bearing locations (registries, launch configs) monitored with alerting (MIR-01)?

Artifacts to Examine

- Publication approval workflow and evidence
- Registry credential issuance records (scopes, lifetimes)
- Agent-artifact signing and provenance records
- Publication egress logs (MIR-01)

Maturity Indicators

Level	Indicator
L1	Agents can reach publication endpoints with standing credentials; no approval gate.
L2	Publication requires human approval; publication credentials reviewed for least privilege.
L3	Signed, scanned, provenance-tracked publication pipeline; short-lived scoped credentials; agent cannot self-approve.
L4	Continuous monitoring and provenance verification of agent-authored artifacts; automated blocking of unapproved publication paths.

Regulatory Mapping: NIST SSDF, ISM (Software Integrity, Change Management), OWASP LLM09 (Misuse of System Access), EU AI Act (Art. 15(b)).

Section 4: Tool and Pipeline Security (TP)

Pillar Overview

Tool and Pipeline Security secures the tools, APIs, plugins, and execution pipelines that the agent invokes. In agentic AI, the agent's power comes from its tools – and its

risk comes from the same source. Every tool is a potential attack surface. A compromised tool can return crafted output that poisons the agent's context (tool output injection). An unregistered tool invoked by a compromised agent can exfiltrate data to an attacker-controlled endpoint. A CI/CD pipeline that deploys agent updates without integrity checks can introduce backdoored agent code.

Why this matters to the client: The difference between a chatbot (talks) and an agent (acts) is tool access. Each tool is a liability. A database query tool in a compromised agent is a data breach. A code execution tool in a compromised agent is a supply chain attack. The SolarWinds supply chain compromise cost impacted organisations an estimated $12B+; an agentic supply chain compromise through an unsecured tool pipeline would have similar magnitude.

Primary stakeholders to interview: Platform Engineering Lead, API Gateway Team, CI/CD Lead, Tool Registry Owner, Vulnerability Management Lead.

TP-01: Tool Inventory and Registry

Explanation Every tool that an agent can invoke – APIs, databases, file systems, code executors, email senders, chatbot integrations – must be registered, versioned, and security-approved before any agent can call it. An unregistered tool is a blind spot: it cannot be monitored, cannot be access-controlled, and cannot be included in the incident response plan. The tool registry is the source of truth for what agents can do.

Key Assessment Questions

1. Is there a central tool registry listing all tools available to agents?
2. Does the registry include metadata (tool owner, version, security review date, data sensitivity)?
3. Are tools security-reviewed before being added to the registry?
4. Is there a process for deregistering deprecated or vulnerable tools?
5. Are agent-to-agent APIs registered as tools in the registry?
6. Is the registry integrated with the authorisation system (no registry entry = no access)?

Artifacts to Examine

- Tool registry system (custom, Backstage, service catalog)
- Tool metadata completeness

- Tool security review records
- Tool registration/deregistration workflow
- Agent-to-agent API tool registrations
- Registry-authorisation system integration

Maturity Indicators

Level	Indicator
L1	No tool registry. Tools documented informally or not at all.
L2	Basic tool registry for critical tools. Manual registration.
L3	Central tool registry with full metadata. Automated security review. Integration with authorisation.
L4	Continuous registry scanning for unregistered tools. Automated deregistration of deprecated tools.

Regulatory Mapping: ISM (Guidelines for Gateways), NIST AI RMF (IDENTIFY – ID.AM).

TP-02: Tool Access Control

Explanation Tool access control ensures that each agent can only invoke the specific tools it is authorised to use, and that each tool authenticates the agent – not the human – before accepting commands. This is tool-level least privilege: the customer support agent can call the CRM read API but not the CRM write API; the financial analyst agent can query the database but not execute shell commands.

Key Assessment Questions

1. Is there a per-agent tool allow-list, or do agents have access to all registered tools?
2. Do tools authenticate the agent identity, or do they trust the identity passed by the agent?
3. Can an agent invoke a tool that its initiating human cannot access?
4. Is tool access evaluated at invocation time (not just at configuration time)?
5. Are tool access policies versioned and auditable?

6. Can tool access be revoked without redeploying the agent?

Artifacts to Examine

- Per-agent tool allow-list configuration
- Tool authentication configuration (does the tool validate agent identity?)
- Tool authorisation policy files
- Tool access audit logs (allowed and denied invocations)
- Tool access revocation process and test results

Maturity Indicators

Level	Indicator
L1	Agents can invoke any registered tool. No per-agent access control.
L2	Per-agent tool allow-lists. Manual assignment.
L3	Tool-level least privilege enforced at invocation time. Agent identity authenticated by tool.
L4	Dynamic tool access assignment based on task and risk. Automated revocation on suspicious activity.

Regulatory Mapping: OWASP LLM08 (Excessive Agency), NIST AI RMF (PROTECT – PR.AC), Essential Eight (Application Control – extended to tools).

TP-03: API Gateway Security

Explanation API gateway security protects every agent-facing API endpoint with rate limiting, payload validation, schema enforcement, and audit logging. The agent-to-tool API surface is often larger and more dynamic than traditional human-facing APIs – agents discover new tools, call tools with programmatic frequency, and can chain multiple tool calls in a single task. The API gateway must handle this at machine speed.

Key Assessment Questions

1. Is there a gateway / proxy between agents and external tools?
2. Does the gateway enforce rate limiting per agent? Per tool?
3. Is payload validation performed against a known-good schema?

4. Are all tool invocations logged with agent identity, tool, input summary, and timestamp?
5. Does the gateway support MCP protocol if MCP-compliant tools are used?
6. Does the gateway fail closed if the audit destination is unreachable?
7. Are new tool endpoints automatically discovered and added to the gateway, or must they be explicitly configured?

Artifacts to Examine

- API gateway configuration (rate limits, schemas, logging)
- Gateway audit logs
- Gateway fail-closed test results
- MCP gateway configuration (if applicable)
- Tool endpoint registration / discovery configuration
- Gateway schema definitions

Maturity Indicators

Level	Indicator
L1	No gateway. Agents call tools directly.
L2	Basic reverse proxy between agents and tools. Rate limiting configured.
L3	Gateway with schema validation, rate limiting, and audit logging. MCP-aware. Fail-closed tested.
L4	Intelligent gateway with dynamic rate limiting, anomaly-based blocking, and auto-discovery. Continuous gateway testing.

Regulatory Mapping: ISM (Guidelines for Gateways, Guidelines for Networking), Essential Eight (Application Control).

TP-04: Tool Output Validation

Explanation Tool output validation ensures that data returned by tools is structurally validated and sanitised before being fed back into the agent's context. This prevents tool output injection attacks – a compromised or malicious tool returning crafted data that causes the agent to behave outside intended parameters. For example, a

database query tool returning a row containing hidden SQL commands that the agent then executes as a new query.

Key Assessment Questions

1. Are tool outputs validated against a known-good schema before entering agent context?
2. Is content-type validation performed (expecting JSON, receiving script)?
3. Are tool outputs sanitised (removing potentially dangerous content) before feeding to the model?
4. Is there a maximum size limit on tool outputs?
5. Are code-generation tool outputs sandbox-executed before affecting production?
6. Are tool output validation failures logged and alerted?

Artifacts to Examine

- Tool output validation schemas and rules
- Tool output sanitisation configuration
- Content-type validation configuration
- Tool output size limits
- Code sandbox configuration and test results
- Tool output validation failure logs

Maturity Indicators

Level	Indicator
L1	No tool output validation. Raw tool responses passed to agent context.
L2	Basic schema validation on tool outputs. Manual review of violations.
L3	Automated schema validation, content-type checking, and sanitisation. Size limits enforced.
L4	Sandbox execution for code-generation tools. Automated blocking of invalid outputs. Continuous validation rule improvement.

Regulatory Mapping: OWASP LLM02 (Insecure Output Handling), NIST AI RMF (MEASURE – ME.AD).

TP-05: Pipeline Integrity

Explanation Pipeline integrity ensures that the CI/CD pipelines that build, test, and deploy agent updates are cryptographically signed, attested, and gated by security validation. An attacker who compromises the pipeline can deploy a backdoored agent to every production environment. Pipeline integrity controls ensure that every deployment is traceable to an approved change, verified by automated tests, and recorded in an immutable audit trail.

Key Assessment Questions

1. Are CI/CD pipeline runs signed and attested (SLSA / in-toto)?
2. Is there a security gate in the pipeline that requires passing SHIELD-AI control tests before deployment?
3. Are pipeline configurations version-controlled and reviewed?
4. Is access to the pipeline restricted and logged?
5. Are third-party pipeline plugins and extensions security-reviewed?
6. Are deployment artifacts stored in an immutable registry with integrity verification?

Artifacts to Examine

- CI/CD pipeline configuration files
- Pipeline signing / attestation configuration
- Security gate configuration (which tests must pass)
- Pipeline access control lists and audit logs
- Third-party plugin security reviews
- Artifact registry configuration (immutable, signed)

Maturity Indicators

Level	Indicator
L1	Pipeline exists but no signing, attestation, or security gates.
L2	Pipeline signed. Basic security tests in pipeline. Access controlled.
L3	SLSA Level 2+ attestation. Automated SHIELD-AI control tests as gates. Immutable artifact registry.
L4	

Level	Indicator
	SLSA Level 3+ attestation. Continuous pipeline security scanning. Automated rollback on integrity failures.

Regulatory Mapping: ISM (Guidelines for Software Development – CI/CD), NIST AI RMF (PROTECT – PR.CI), Essential Eight (Application Control – restricted execution).

TP-06: Dependency Scanning

Explanation Dependency scanning ensures that all libraries, models, and tools used by the agent are continuously scanned for known vulnerabilities, with automated blocking for critical-severity findings. The AI supply chain is particularly vulnerable to dependency-level attacks because ML libraries and model registries are frequent targets – a compromised package on PyPI or a backdoored model on HuggingFace can affect every organisation that depends on it.

Key Assessment Questions

1. Are ML libraries (PyTorch, TensorFlow, transformers) scanned for vulnerabilities?
2. Are model weights and configurations scanned?
3. Are tool SDKs and plugins scanned?
4. Is there automated blocking for critical-severity findings, or just alerts?
5. Is scanning performed continuously (not just at build time)?
6. Are dependency updates automatically tested and deployed?
7. Are base container images scanned for the agent runtime?

Artifacts to Examine

- Dependency scanning tool configuration
- Vulnerability scan reports (ML and non-ML dependencies)
- Automated blocking configuration
- Dependency update policy and automation
- Container image scanning configuration
- SBOM for agent runtime dependencies

Maturity Indicators

Level	Indicator
L1	No dependency scanning. Dependencies updated ad-hoc.
L2	Basic scanning at build time. Manual review of critical findings.
L3	Continuous scanning. Automated blocking for critical findings. Automated patch deployment.
L4	AI-specific dependency scanning (ML libraries, model registries). Predictive vulnerability assessment.

Regulatory Mapping: OWASP LLM10 (Supply Chain), ISM (Guidelines for System Management – vulnerability management), Essential Eight (Patch Applications, Patch Operating Systems).

TP-07: Cross-Tool Dependency Analysis

Explanation Before an agent is deployed, all registered tools must be analysed for transitive risk – combinations of tool permissions that could enable sandbox escape, privilege escalation, or data exfiltration when chained. Tool combinations that enable multi-step escape chains must be flagged with automated risk scoring and require explicit risk acceptance via GRM-02 before deployment.

Key Assessment Questions

1. Is every tool classified by its potential to contribute to an escape chain (network_write, file_write, code_execution, identity_escalation, data_query)?
2. Are tool combinations analysed for chained risk before deployment?
3. Do combinations that create an escape-class chain (e.g., network_write + code_execution) trigger blocking review?
4. Are any escape-class tool chains deployed with explicit risk acceptance via GRM-02?
5. Is the analysis automated and re-run when tools change?

Artifacts to Examine

- Tool classification registry (per-tool escape-chain categories)
- Cross-tool dependency analysis reports

- Risk acceptance records (GRM-02) for escape-class chains
- Automated chain-analysis configuration and outputs

Maturity Indicators

Level	Indicator
L1	No cross-tool analysis; tools assessed in isolation.
L2	Manual review of tool combinations for critical agents.
L3	Automated risk scoring of tool combinations; escape-class chains blocked or risk-accepted via GRM-02.
L4	Continuous chain analysis on every tool change; automated blocking of new escape-class combinations.

Regulatory Mapping: OWASP LLM08 (Excessive Agency), NIST AI RMF (MANAGE – MG.DE), EU AI Act (Art. 9(4)).

TP-08: API Gateway Infrastructure-Isolation Mode

Explanation API gateways for agents must implement an allow-list of permitted API endpoints that explicitly excludes all cloud infrastructure control-plane APIs (EC2, IAM, Lambda, KMS, CloudFormation, S3 control-plane, Azure Resource Manager, GCP Cloud Resource Manager). Any attempt by an agent to call a non-tool API must be logged, blocked at the gateway level, and treated as a potential indicator of compromise.

Key Assessment Questions

1. Does the gateway enforce an allow-list of permitted API endpoints?
2. Are all cloud infrastructure control-plane APIs excluded from the allow-list?
3. Is any attempt by an agent to call a non-tool API logged and blocked?
4. Are infrastructure APIs only accessible if explicitly registered as tools via TP-01 with documented security rationale and risk acceptance?
5. Do blocked infrastructure-API attempts trigger an alert (MIR-01)?
6. Is the allow-list tested regularly against known control-plane API endpoints?

Artifacts to Examine

- Gateway allow-list configuration

- Blocked-request logs for infrastructure API attempts
- Tool registration records (TP-01) for any infrastructure access
- Infrastructure-API bypass test results

Maturity Indicators

Level	Indicator
L1	Agents can reach infrastructure APIs directly or via default gateway routing.
L2	Gateway present; infrastructure APIs blocked by policy but not consistently tested.
L3	Explicit allow-list excluding all control-plane APIs; blocked attempts logged and alerted as potential compromise.
L4	Continuous testing of the allow-list against provider endpoint inventories; automated addition of new provider endpoints to the block list.

Regulatory Mapping: ISM (Guidelines for Gateways), NIST AI RMF (PROTECT – PR.PT), EU AI Act (Art. 15(b)).

TP-09: Explicit Tool Registration

Explanation Agent frameworks must not auto-register internal functions, SDK helpers, or framework internals as agent-callable tools. Every function callable by the agent must be explicitly declared in the tool registry via TP-01. This includes preventing attribute-based tool registration (e.g., [KernelFunction]-style attributes), reflection-based tool discovery, and automatic exposure of internal helpers.

Key Assessment Questions

1. Is framework auto-registration of tools disabled by default?
2. Are all discoverable callables audited against the TP-01 registry before deployment?
3. Is any callable not explicitly registered blocked from agent invocation?
4. Are attribute-based registration, reflection-based discovery, and internal-helper exposure prevented?

5. Was the agent framework checked for implicit tool exposure CVEs (e.g., CVE-2026-25592, CVE-2026-26030)?

Artifacts to Examine

- Framework tool-registration configuration (auto-registration disabled)
- TP-01 tool registry (explicit declarations)
- Callable-discovery audit results
- Agent framework CVE scan and patch records

Maturity Indicators

Level	Indicator
L1	Frameworks auto-expose internal functions as tools; no registry enforcement.
L2	Explicit registry for critical tools; auto-registration partially disabled.
L3	Auto-registration disabled by default; all discoverable callables audited; unregistered callables blocked.
L4	Continuous callable-audit in CI/CD; automated blocking of any implicitly exposed tool.

Regulatory Mapping: OWASP LLM08 (Excessive Agency), NIST AI RMF (IDENTIFY – ID.AM), EU AI Act (Art. 15(b)).

TP-10: Agent Platform Inbound Control-Plane Protection

Explanation The agent platform's gateway, control plane, and any service the platform or an agent binds must be treated as an inbound attack surface, not merely as an outbound actor. All listeners — loopback, LAN, MCP endpoints, webhook receivers, debug interfaces — are governed by a network-binding policy defaulting to deny, enforced at the OS/namespace boundary. Gateway tokens and operator credentials are least-privilege scoped, never readable from web or browser context, and bound to validated origins (cross-site WebSocket hijack-resistant session handling). Accidental or agent-initiated service binding is detected, reported, and blocked absent explicit approval; the binding guard fails closed on error. OpenClaw CVE-2026-25253 (CVSS 8.8) demonstrated the class: a crafted link triggered cross-site WebSocket hijacking of a loopback-only local gateway, exfiltrating an operator-

scoped token that disabled user confirmation, escaped the shell container, and achieved host RCE — the victim's browser acted as the bridge, so loopback binding was no protection.

Key Assessment Questions

1. Are all agent-platform listeners (loopback, LAN, MCP, webhooks, debug) inventoried and governed by a default-deny binding policy?
2. Can gateway/operator tokens be read from web or browser context (CSWSH test)?
3. Is origin validation enforced on gateway WebSocket/SSE sessions?
4. Are accidental or agent-initiated service bindings detected and blocked?
5. Does the binding guard fail closed when it errors?

Artifacts to Examine

- Network-binding policy configuration
- Gateway session origin-validation rules
- Listener inventory and drift reports
- CSWSH/origin-validation test results

Maturity Indicators

Level	Indicator
L1	Listeners ungoverned; gateway tokens reachable from web/browser context.
L2	Listener inventory maintained; origin validation on gateway sessions; token scope review.
L3	Default-deny binding policy enforced; no standing allow rules; automated detection of new listeners; no operator-scope tokens readable from web context.
L4	Continuous adversarial testing of the inbound surface; binding-policy attestation in the audit trail; periodic re-certification of all allow rules.

Regulatory Mapping: ISM (Web Application Hardening, Network Segmentation), OWASP LLM09 (Misuse of System Access), NIST AI RMF (PROTECT – PR.AC), EU AI Act (Art. 14).

TP-11: Agent Browser and Content-Rendering Isolation

Explanation Agent browser runtimes and any component that renders and interprets untrusted content — agentic browsers, document processors in AI assistants, rendered web pages — must preserve origin and content isolation. Agentic browsers that dismantle the Same-Origin Policy to act across sites convert every page the agent reads into a potential command source: invisible instructions (white-on-white text, zero-opacity overlays, CSS-hidden elements) in any content the agent perceives are executed as if they were the user's commands. Zenity Labs' Intent Collision research (Black Hat USA 2026) demonstrated zero-click takeover of Claude in Chrome, Gemini, Perplexity Comet, ChatGPT Atlas, and Copilot Edge — cross-tab token theft, email exfiltration, and unauthorised financial transfers — with several vendors characterising the attack as intended functionality. Rubrik Zero Labs' Remote Prompt Execution chain against Microsoft 365 Copilot showed a single poisoned document upload can seed prompt injection, sandbox escape (CVE-2026-32193 path traversal plus LD_PRELOAD), and a bidirectional shell inheriting the victim's identity. Rendered content must be classified as untrusted input and stripped of imperceptible instruction vectors before agent action; cross-origin privileged actions must be gated by the same approval and isolation rules as any other high-risk tool action; the browser/session layer must be isolated from credential material; and document uploads must be sanitised before assistant processing.

Key Assessment Questions

1. Can content rendered by the agent's browser or a processed document execute privileged actions without approval?
2. Are imperceptible instruction vectors stripped from rendered content before agent action?
3. Is origin isolation preserved in agent browser runtimes (no cross-origin token access)?
4. Are document uploads sanitised before assistant processing (Remote Prompt Execution class)?
5. Is the browser/session layer isolated from the agent's credential material?

Artifacts to Examine

- Browser/session isolation configuration
- Rendered-content sanitisation rules
- Cross-origin action gating policy

• Red-team results (Intent Collision / RPE class)

Maturity Indicators

Level	Indicator
L1	Agent uses browser/document rendering as-is; no content classification.
L2	Hidden-content scanning on rendered pages and uploaded documents; cross-origin actions flagged for review.
L3	Origin isolation preserved in agent browser runtimes; no cross-origin token access; imperative action gating (approval required for financial and credential operations); document uploads sanitised before assistant processing.
L4	Continuous adversarial testing of the rendering layer; origin-isolation attestation; red-team validation against zero-click chains (PleaseFix/Intent Collision class).

Regulatory Mapping: OWASP LLM01 (Prompt Injection), NIST AI RMF (PROTECT – PR.AC), EU AI Act (Art. 15), ISM (Web Content Filtering).

TP-12: Tool-Call Provenance and Dispatch Verification

Explanation Every tool execution must verify that the tool-call instruction originated from an authorised model turn or an explicitly authorised caller. The dispatch layer must not treat data shaped like a model-generated tool call as authoritative without provenance verification: tool calls carry cryptographically bound provenance (session, turn, model signature) that is verified before dispatch; session history and event streams are authenticated so attacker-injected events cannot fabricate tool calls or approval confirmations; approval records bind to the exact tool call (tool name and arguments) they authorise and are verified against the human approver channel, never against session history the agent can write; and the inspection-execution gap fails closed — no provenance, no dispatch. Stealth's CoreBreak research (Black Hat USA 2026) identified the structural class across the three major agent platforms: AWS Bedrock AgentCore (CVE-2026-18830, CVSSv4 8.6 — an authenticated remote caller injected a tool-use content block into an InvokeHarness

request and the event loop dispatched the tool without model authorisation), Google Agent Development Kit (CVE-2026-18236, CVSSv4 9.3 — attacker-controlled session events forged a human-approval confirmation because the confirmation processor never verified tool ownership or argument matches), and Vercel AI SDK harness packages (CVE-2026-64650/64651, CVSSv4 6.3 — a process-path check trusted any process whose command line contained an approved helper path). CoreBreak is distinct from prompt injection: the model is bypassed altogether at the dispatch layer, so system prompts, refusal training, and content filters cannot help.

Key Assessment Questions

1. Can a tool execute without a verified, authorised model turn?
2. Can attacker-injected session or event history fabricate a tool call or an approval confirmation?
3. Do approval records bind to the exact tool call (name and arguments) they authorise?
4. Is approval evidence verified against the human approver channel, never against agent-writable session history?
5. Does dispatch fail closed when tool-call provenance cannot be verified?

Artifacts to Examine

- Dispatch-layer provenance verification configuration
- Session/event history authentication controls
- Approval-record binding policy
- Red-team results (CoreBreak class)

Maturity Indicators

Level	Indicator
L1	Dispatch executes any data shaped like a tool call; no provenance checks.
L2	Tool calls carry basic session identifiers; dispatch verifies call structure only.
L3	Tool calls carry cryptographically bound provenance (session, turn, model signature) verified before dispatch; session/event history authenticated; approval records bind to tool name and arguments and verify

Level	Indicator
	against the human approver channel; fail closed on unverifiable provenance.
L4	Continuous provenance attestation on all dispatches; red-team testing of the dispatch layer (CoreBreak class); automated blocking of provenance-less tool calls across all harnesses and MCP servers.

Regulatory Mapping: OWASP LLM08 (Excessive Agency), NIST AI RMF (PROTECT – PR.AC), EU AI Act (Art. 14(b)), ISM (Guidelines for Gateways).

TP-13: Agent Dependency-Install Provenance Verification

Explanation Agents must not execute installation commands derived from ingested content — documentation pages, llms.txt/llms-full.txt files, setup guides, README instructions — without verifying the provenance of every package, domain, and command they reference. Package names are confirmed to exist in the intended registry and the namespace is verified to belong to the documented vendor (registry ownership checks, domain registration and expiry checks) before any pip/npm/npx/apt/go install or clone executes. Installation commands sourced from untrusted or ingested content are gated by an operator-maintained allowlist or human approval instead of being treated as authoritative setup steps. Dangling references — commands pointing to unregistered packages, unclaimed or expired domains, or namespaces that do not match the publisher — are treated as security findings that block the install, log via MIR-01, and surface for review. A documentation file is never treated as an authoritative install script. The llms.txt class (Ars Technica, August 27, 2026): 120 of 8,265 scanned llms.txt files referenced unregistered packages; registering the names produced code-execution phone-homes from Fortune 500 companies within an hour; Claude, Codex, and Hermes coding agents ran the installs, and the Clerk.com case had live malware hosted on an unclaimed npx slot.

Key Assessment Questions

1. Do agents execute installation commands from documentation without verifying package existence and namespace ownership?
2. Are installs derived from untrusted content gated by an allowlist or human approval?

3. Are dangling references (unregistered packages, unclaimed domains) blocked, logged, and surfaced as findings?
4. Is a documentation file ever treated as an authoritative install script?

Artifacts to Examine

- Dependency-install provenance verification configuration
- Registry namespace and domain-ownership check results
- Install-command allowlist / approval policy
- Dangling-reference findings and MIR-01 alerts

Maturity Indicators

Level	Indicator
L1	Agents execute install commands found in documentation or llms.txt verbatim with no namespace checks.
L2	Install commands from ingested content run, but package/domain existence is only checked post-hoc.
L3	Pre-install provenance verification: registry existence, namespace ownership, domain registration; installs from untrusted content gated by an allowlist or human approval; dangling references blocked and logged via MIR-01.
L4	Continuous verification against live registry state; automated blocking of dangling references; documentation files never treated as authoritative install scripts; red-team testing of the docs-to-install path.

Regulatory Mapping: OWASP LLM08 (Excessive Agency), NIST AI RMF (PROTECT – PR.DS), EU AI Act (Art. 14 – Human Oversight), ISM (Guidelines for Gateways).

TP-14: Skill/Plugin Payload Integrity and Instruction-Channel Isolation

Explanation Skills, plugins, and marketplace extensions must be distributed as cryptographically signed, immutable payloads whose instruction content is fixed at install time. Runtime-fetchable instruction channels — remote referral manifests, update feeds, and operator-controlled configuration fetched after install — are prohibited and must be blocked at the network and runtime layers, because a post-install fetch channel is a command-and-control path invisible to monitoring (it is not a tool call). Skills execute with privileges scoped to their declared capability set, never the agent's full identity, and a post-install behavioural baseline must be established under MIR-02 before full capability is granted, with baseline drift quarantining the skill. Marketplace provenance must be attestable end-to-end (publisher to registry to artifact) with publisher identity attestation. On any signature, provenance, or baseline error the install is blocked and installed skills are suspended; runtime-fetch attempts terminate the skill and alert via MIR-01 — never unsigned execution. The ClawHavoc/ClawHub class (Koi Security, February 2026; Antiy CERT: 1,184 malicious skills, approximately 20% of the registry; Unit 42, June 2026: evasive skills passing automated scanning, runtime affiliate injection, agentic front-running) demonstrated that installing a skill is an unreviewed code-execution event with the agent's full privileges.

Key Assessment Questions

1. Are skills/plugins verified for signature and provenance before install?
2. Are runtime-fetchable instruction channels (remote manifests, update feeds) blocked?
3. Do skills execute with privileges scoped to their declared capability set, not the agent's full identity?
4. Is a post-install behavioural baseline established and drift-quarantined?

Artifacts to Examine

- Skill/plugin signature and provenance verification configuration
- Runtime-fetch network-block policy and alerts
- Skill privilege-scope declarations and execution audit
- Post-install behavioural baseline records and drift alerts (MIR-02)

Maturity Indicators

Level	Indicator
L1	Skills installed ad hoc from any marketplace with no signature or provenance checks; full agent privileges.
L2	Signature verification at install; marketplaces restricted to an operator allowlist.
L3	Immutable signed payloads; runtime-fetch channels blocked; privilege-scoped execution; post-install baseline with drift quarantine.
L4	End-to-end provenance attestation at registry and runtime; cross-org telemetry sharing on malicious-skill signals; red-team testing of the install path.

Regulatory Mapping: OWASP LLM08 (Excessive Agency), NIST AI RMF (PROTECT – PR.DS), EU AI Act (Art. 14 – Human Oversight), ISM (Guidelines for Software Development, Application Control).

TP-15: In-Process Code-Execution Sandbox Sufficiency

Explanation Denylist- and blocklist-based in-process code-execution sandboxes — code interpreters that confine LLM/agent-generated source by enumerating forbidden modules, attributes, calls, or string constants within the same process — must be treated as code-execution surfaces, not security boundaries. This class is structurally bypassable: each denied primitive is one forgotten object-graph edge away from recovery of the full host context, and adversarial capability escalation re-derives arbitrary execution from any surviving reachable built-in or bridge. Therefore any LLM-generated or untrusted code destined for in-process execution must run inside an OS- or VM-level isolation boundary (containers, VMs, gVisor-style runtimes, or dedicated subprocesses with kernel-enforced separation — EE-01) with no shared host filesystem or IPC. In-process interpreter gates must not be deployed as the sole containment for untrusted code; where an in-process sandbox is unavoidable, it is classified in the TP-06 HIGH-RISK dependency class with automated blocking on critical findings and a mandatory alternative-evaluation gate for any L3+ deployment. The denylist-sandbox bypass wave — PraisonAI CVE-2026-47392 (print.__self__ builtins recovery, vars(), runtime string concatenation; survived the prior patches CVE-2026-39888/34938/40158) and CrewAI CVE-2026-37008 (module-name blocklist bypassed via ctypes.CDLL(None) without any import, yielding arbitrary native host execution) — demonstrated that blocklist enumeration cannot be

completed and every patch merely relocates the cliff. The in-process rule extends beyond denylists to any same-process isolation scheme that separates untrusted from trusted code by an in-process mechanism: separate language contexts or VMs within a single host process are not security boundaries when they share a memory heap or when a trust secret (an authorisation token between trusted and untrusted code) lives in memory the untrusted side can read — OpenAI Codex Heapjack (INC-65, September 2026) recovered the trusted token from a shared V8 heap in node_repl to forge requests to the native parent for host RCE, confirming that same-process trusted/untrusted separation must be replaced by process-, container-, or VM-level isolation with the authorisation secret held outside the untrusted memory space.

Key Assessment Questions

1. Have all code-execution paths used by agents been audited to confirm they do not rely on an in-process denylist/blocklist gate as the sole boundary?
2. Does every LLM-generated or untrusted code execution run inside an OS/VM-level isolation boundary (EE-01)?
3. Are unavoidable in-process sandboxes tracked as a HIGH-RISK dependency class with automated blocking and an L3+ alternative-evaluation gate?
4. Can object-graph bypass primitives (builtins recovery, ctypes, string-constructed names) reach host execution from any agent code path?
5. Does any in-process isolation rely on same-process context separation (multiple language contexts/VMs in one process) where a trust secret (authorisation token) lives in memory the untrusted side can read? If so, is it replaced by process-, container-, or VM-level isolation with the secret held outside the untrusted memory space?

Artifacts to Examine

- Code-execution tool inventory and boundary classification
- EE-sandbox routing policy for model-generated code
- In-process sandbox HIGH-RISK dependency tracking and blocking alerts (TP-06)
- Red-team object-graph bypass test results

Maturity Indicators

Level	Indicator
L1	

Level	Indicator
	Agent frameworks run LLM-generated code in an in-process denylist/blocklist sandbox as the sole containment; host code-execution primitives reachable.
L2	Code-execution tools identified and routed to an OS/VM-level sandbox (EE-01); in-process gates flagged and scheduled for replacement.
L3	In-process sandboxes locked in the HIGH-RISK dependency class (TP-06) with automated blocking on critical findings; model-generated code executes only in the EE sandbox.
L4	No in-process gate deployed for untrusted code; all model-generated execution is OS/VM-isolated with provenance receipts (TP-12); red-teamed object-graph bypass attempts in CI.

Regulatory Mapping: OWASP LLM08 (Excessive Agency), NIST AI RMF (PROTECT – PR.DS), EU AI Act (Art. 14 – Human Oversight), ISM (Guidelines for Software Development and System Management).

Section 5: Monitoring, Logging, and Incident Response (MIR)

Pillar Overview

Monitoring, Logging, and Incident Response detects and responds to security incidents involving agentic AI systems. Traditional monitoring was designed for static applications and known attack signatures. Agentic AI monitoring must detect behavioural anomalies (not just signature matches), track agent actions across tool call chains, and support AI-specific incident response procedures (prompt injection containment, model rollback, tool access revocation, session invalidation). Speed matters: an agentic AI compromise can execute its entire attack chain in seconds.

Why this matters to the client: An agentic AI compromise can execute its entire attack chain – from initial prompt injection to data exfiltration – faster than a human can detect. Without AI-specific monitoring, you will not know an agent has been compromised until the data is already exfiltrated. The SOCI Act requires critical infrastructure entities to report incidents within 12 hours. Without monitoring controls, you cannot meet that obligation.

Primary stakeholders to interview: SOC Lead, SIEM Engineer, Incident Response Lead, Threat Intelligence Lead, Compliance Reporting Lead.

MIR-01: Agent Activity Logging

Explanation Agent activity logging captures every action an agent takes – every tool invocation, data access, decision, and error – in a structured, auditable format. Each log entry includes agent identity, session ID, timestamp, action type, action target, action result, and a correlation ID that ties the event to the human-initiating session. This is the foundation for anomaly detection, incident investigation, and regulatory reporting.

Key Assessment Questions

1. Are all agent actions logged (every tool call, data access, decision, error)?
2. Is each log entry structured with agent ID, session ID, timestamp, action type, target, result?
3. Is there a correlation ID that ties agent actions to the initiating human session?
4. Are logs stored in an immutable append-only store?
5. Is log integrity verifiable (tamper detection)?
6. Are logs accessible to the SOC with minimal latency?
7. Are agent logs integrated with existing SIEM / logging infrastructure?
8. For multi-agent architectures, does logging support distributed tracing across agent boundaries?

Artifacts to Examine

- Log schema definition (agent event structure)
- Agent telemetry pipeline configuration
- Log storage configuration (immutability, retention)
- Log integrity verification mechanism

- SIEM integration configuration
- Log query examples (can the SOC find a specific agent's actions?)
- Log coverage report (are all agents logging?)
- Distributed tracing header propagation (multi-agent)

Maturity Indicators

Level	Indicator
L1	Basic agent logs (start, stop). Limited structure. Stored locally.
L2	Structured audit logs for all agent actions. Centralised storage. 30-day retention.
L3	Immutable logs. Correlation IDs across multi-agent chains. SIEM integration. Log integrity verification.
L4	Real-time log streaming. Automated log anomaly detection. Extended retention for forensic readiness.

Regulatory Mapping: SOCI Act (s.30B(5)(a) – record-keeping), APRA CPS 234 (s.3(c) – information security capability), ISM (Guidelines for System Monitoring).

MIR-02: Behavioural Anomaly Detection

Explanation Behavioural anomaly detection establishes per-agent and per-agent-class behaviour baselines and alerts when an agent deviates. Unlike traditional anomaly detection (which looks for known attack signatures), agent behavioural detection learns what "normal" looks like for each agent – which tools it calls, how frequently, what data it accesses, and what decisions it makes – and flags deviations. This catches attacks that signature-based detection misses.

Key Assessment Questions

1. Are per-agent behaviour baselines established (what is normal for this specific agent)?
2. Are per-agent-class baselines established (what is normal for this type of agent)?
3. What deviation thresholds trigger alerts? Are they tuned per agent?
4. Are memory access patterns monitored (agent reading records it should not access)?

5. Are tool invocation patterns monitored (unusual tool, unusual frequency, unusual chain)?
6. Are anomaly alerts integrated with the SOC/SOAR?
7. Are false positives reviewed and used to improve baseline accuracy?

Artifacts to Examine

- Behavioural baseline definitions
- Anomaly detection rule configuration
- Recent anomaly alerts and their disposition
- Baseline tuning / calibration records
- Memory access monitoring configuration
- Tool invocation monitoring configuration
- SOC integration configuration

Maturity Indicators

Level	Indicator
L1	No anomaly detection. Signature-based monitoring only (if any).
L2	Basic per-agent baselines. Manual alert review.
L3	Per-agent and per-class baselines. Automated alerting. Integration with SOC. Regular tuning.
L4	Continuous baseline learning. Cross-agent anomaly correlation. Predictive anomaly detection.

Regulatory Mapping: NIST AI RMF (DETECT – DE.CM), ISM (Guidelines for System Monitoring).

MIR-03: Prompt Audit Log

Explanation The prompt audit log captures sanitised prompt/response pairs for forensic analysis while protecting sensitive data. Full prompts and responses are logged temporarily for incident investigation, with sensitive fields (PII, credentials, internal URLs) automatically redacted in long-term storage. This is the AI-equivalent

of database query logging – it enables investigators to reconstruct what the agent was asked and what it did.

Key Assessment Questions

1. Are prompt/response pairs logged with agent identity and session ID?
2. Is sensitive data automatically redacted before long-term storage?
3. Is there a mechanism to recover redacted data for incident investigation?
4. How long are full (unredacted) prompts retained? Redacted prompts?
5. Are prompt logs accessible to the SIEM/SOC?
6. Is there a process for reviewing prompt logs for security incidents?
7. Are prompt logs included in the data retention and disposal schedule?

Artifacts to Examine

- Prompt logging configuration (redaction rules, retention periods)
- Prompt log storage architecture
- Redaction recovery mechanism (for legitimate IR use)
- Prompt log retention policy
- Prompt log query examples
- Prompt log review process documentation

Maturity Indicators

Level	Indicator
L1	No prompt logging.
L2	Basic prompt/response logging. Manual review. Short retention.
L3	Automated redaction. Tiered retention (full -> redacted). SIEM integration.
L4	Real-time prompt scanning for security events. Automated incident triggering from prompt analysis.

Regulatory Mapping: OWASP LLM01 (Prompt Injection – detection), NIST AI RMF (DETECT – DE.AE), EU AI Act (Art. 12 – Transparency).

MIR-04: Incident Response Playbooks

Explanation Incident response playbooks define AI-specific procedures for detecting, containing, and recovering from security incidents involving agentic AI. These are distinct from general IT incident response playbooks because they address AI-unique scenarios: prompt injection containment (block the injected prompt, revoke agent's tool access, roll back model state), model compromise (remove compromised weights, restore from verified checkpoint), and tool abuse (revoke tool access for affected agents, audit tool invocation logs for the incident window).

Key Assessment Questions

1. Are there AI-specific IR playbooks, or does the organisation rely on general IR procedures?
2. What incident scenarios are covered (prompt injection, data exfiltration, model compromise, tool abuse, code-generation attack)?
3. Are playbooks tested (tabletop exercises, simulations)?
4. Are playbooks integrated with SOAR for automated response?
5. Are playbook updates triggered by new attack techniques?
6. Is there a process for post-incident review and playbook improvement?

Artifacts to Examine

- AI-specific IR playbook documents
- Tabletop exercise records and findings
- SOAR playbook configuration
- Post-incident review records
- Playbook update history
- IR team training records (AI-specific training)

Maturity Indicators

Level	Indicator
L1	No AI-specific IR playbooks. General IR procedures applied ad-hoc.
L2	Basic AI-specific playbooks documented. Manual response.

Level	Indicator
L3	Comprehensive playbooks for all AI incident types. SOAR integration. Regular tabletop exercises.
L4	Automated playbook execution for known incident types. Continuous playbook improvement from threat intelligence. AI-specific IR team training.

Regulatory Mapping: NIST AI RMF (RESPOND – RS.RP), SOCI Act (CIRMP – incident response), APRA CPS 234 (s.3(c) – incident response capability).

MIR-05: Mandatory Reporting Integration

Explanation Mandatory reporting integration ensures that the organisation can meet regulatory incident reporting deadlines – SOCI Act 12/72-hour windows, APRA CPS 234 72-hour notification, and Privacy Act Notifiable Data Breaches reporting. The control provides automated triggers that detect reportable incidents, pre-populated incident report templates, and escalation workflows to the relevant regulatory body.

Key Assessment Questions

1. Are SOCI Act/APRA/NDB reporting triggers integrated with agent monitoring?
2. Are incident report templates pre-populated with agent data (timeline, affected systems, data types)?
3. Is there an escalation workflow that notifies the designated reporting officer?
4. Is the reporting integration tested (not just documented)?
5. Are reporting deadlines tracked and alerted to compliance teams?
6. Are historical incident reports available for regulatory review?

Artifacts to Examine

- Reporting trigger configuration (which events trigger which reports)
- Incident report templates
- Escalation workflow documentation and test results
- Reporting deadline tracking configuration
- Historical incident report repository
- Regulatory communication records

Maturity Indicators

Level	Indicator
L1	No automated reporting. Incidents reported manually (if at all).
L2	Manual incident reports using templates. Deadlines tracked in spreadsheets.
L3	Automated incident detection triggers pre-populated reports. Escalation workflows active.
L4	Fully automated reporting lifecycle. Continuous compliance monitoring with regulator dashboards.

Regulatory Mapping: SOCI Act (s.30B – mandatory incident reporting – 12h critical, 72h other), APRA CPS 234 (s.3(c) – 72-hour notification), Privacy Act (Notifiable Data Breaches scheme).

MIR-06: Forensic Readiness

Explanation Forensic readiness ensures that the organisation can reconstruct a full agent session – every prompt, tool call, data access, decision, and response – for post-incident investigation. Logs are written to immutable, append-only storage with integrity guarantees. Session reconstruction enables investigators to determine precisely what happened, what data was accessed, and what actions were taken during a security incident.

Key Assessment Questions

1. Are logs written to immutable, append-only storage?
2. Is log integrity verifiable (cannot be modified or deleted without detection)?
3. Can a full agent session be reconstructed (every action in sequence)?
4. For multi-agent chains, can the full chain be reconstructed?
5. Are logs retained for the regulatory-required period (at minimum)?
6. Is there a forensic data extraction process that does not alter log integrity?
7. Are forensic tools available for analysing agent-specific log formats?

Artifacts to Examine

- Log storage architecture (immutability, append-only)
- Log integrity verification mechanism (checksums, blockchain, WORM storage)

- Session reconstruction capability demonstration
- Log retention policy (meeting regulatory minimums)
- Forensic tool configuration
- Forensic data extraction procedure

Maturity Indicators

Level	Indicator
L1	Logs stored in standard database. Can be modified. Retention ad-hoc.
L2	Logs in append-only storage. Basic retention policy.
L3	Immutable logs with integrity verification. Full session reconstruction capability. Multi-agent chain reconstruction.
L4	Real-time forensic readiness verification. Automated forensic data extraction. Continuous integrity monitoring.

Regulatory Mapping: NIST AI RMF (RECOVER – RC.RP), ISM (Guidelines for Cyber Security Incidents – forensic readiness), SOCI Act (CIRMP – record-keeping).

Section 6: Governance and Risk Management (GRM)

Pillar Overview

Governance and Risk Management establishes the organisational structures, policies, and risk processes for safe agentic AI. This is the pillar that makes all other pillars sustainable – without governance, technical controls erode over time as people leave, systems change, and threats evolve. It covers the AI governance body (who decides), the AI risk register (what we are worried about), ethical use policy (what agents are allowed to do), third-party risk management (who we trust),

regulatory mapping (what we must comply with), and board reporting (how we demonstrate accountability).

Why this matters to the client: APRA CPS 234 explicitly makes the Board responsible for information security. In an age of agentic AI, this means the Board is responsible for AI security. Without a governance structure that documents who decides, who approves, and who is accountable, Board members cannot discharge their duty of care.

Primary stakeholders to interview: CISO, CRO, General Counsel, AI Governance Lead, Chief Data Officer, Head of Compliance.

GRM-01: AI Governance Body

Explanation The AI governance body is a chartered committee with the authority to approve agentic AI deployments, define acceptable use boundaries, and oversee the organisation's AI security posture. The committee must include the CISO, CRO, General Counsel, data owner, and AI lead – reflecting that AI security is not just a technology issue but a risk, legal, data, and operational issue.

Key Assessment Questions

1. Is there a chartered AI governance body with defined terms of reference?
2. Who sits on the committee (CISO, CRO, GC, data owner, AI lead)?
3. What decisions require committee approval (new agent deployments, scope changes, exception approvals)?
4. How often does the committee meet?
5. Are committee decisions documented and tracked?
6. Is there an escalation path for decisions the committee cannot resolve?
7. Is committee membership reviewed periodically?

Artifacts to Examine

- AI governance body charter and terms of reference
- Committee meeting minutes and decision records
- Committee membership list and review schedule
- Escalation procedure documentation
- Decision implementation tracking

Maturity Indicators

Level	Indicator
L1	No AI governance body. AI decisions made by individual teams.
L2	Informal AI governance group meets ad-hoc. No formal charter.
L3	Chartered AI governance body with defined terms of reference. Regular meetings. Documented decisions.
L4	AI governance body with delegated authority. Independent audit of decisions. Cross-entity governance for multi-unit organisations.

Regulatory Mapping: APRA CPS 234 (s.2 – Board accountability), PSPF (Security Governance – Policy 1), Privacy Act (APP 1 – accountability).

GRM-02: AI Risk Register

Explanation The AI risk register is a distinct register (or distinct section of the enterprise risk register) that captures AI-specific risks using a dedicated threat taxonomy. This includes model-level risks (poisoning, prompt injection), tool-level risks (tool output injection, credential delegation), data-level risks (cross-session aggregation, training data leakage), identity-level risks (excessive agency), and pipeline-level risks (supply chain compromise). Each risk is assessed, owned, and tracked to resolution.

Key Assessment Questions

1. Is there a dedicated AI risk register or AI-specific section in the enterprise risk register?
2. Does the AI risk taxonomy cover model, tool, data, identity, and pipeline risks?
3. Are risks assessed using a defined methodology (likelihood x impact)?
4. Are risk owners assigned to each AI risk?
5. Are risks reviewed and updated on a regular cadence?
6. Is there a process for accepting AI risks with documented rationale and expiry?
7. Is the AI risk register reviewed by the AI governance body?

Artifacts to Examine

- AI risk register entries
- AI risk taxonomy documentation
- Risk assessment methodology
- Risk owner assignments
- Risk review schedule and records
- Risk acceptance records with rationale and expiry

Maturity Indicators

Level	Indicator
L1	No AI risk register. AI risks captured informally or not at all.
L2	Basic AI risk register with manual entries. Siloed from enterprise risk register.
L3	AI-specific risk taxonomy in enterprise risk register. Regular review cycle. Formal risk acceptance.
L4	Continuous AI risk assessment. Automated risk scoring from control monitoring. Integrated with enterprise risk management.

Regulatory Mapping: NIST AI RMF (GOVERN – GV.RM), SOCI Act (CIRMP – risk management), APRA CPS 234 (s.3(a) – risk assessment).

GRM-03: Ethical Use Policy

Explanation The ethical use policy defines what agents are allowed and not allowed to do, what level of autonomy they may have based on risk tier, and what transparency obligations apply. This is the “terms of use” for agentic AI within the organisation – it sets boundaries that the technical controls then enforce.

Key Assessment Questions

1. Is there an approved ethical use policy for agentic AI?
2. Does the policy define acceptable use boundaries (what agents can and cannot do)?
3. Are agents classified into risk tiers with corresponding autonomy levels?

4. Does the policy specify transparency obligations (disclosure that an interaction involves an AI)?
5. Is the policy reviewed and updated on a regular cadence?
6. Is policy compliance monitored and enforced by technical controls?
7. Are policy violations investigated and remediated?

Artifacts to Examine

- AI ethical use policy document
- Agent risk classification methodology and classifications
- Policy compliance monitoring configuration
- Policy violation records and remediation
- Policy review schedule and update history

Maturity Indicators

Level	Indicator
L1	No ethical use policy. Agents deployed without defined boundaries.
L2	Draft policy document. Basic risk classification. Manual compliance monitoring.
L3	Approved policy with risk-tiered autonomy. Automated compliance monitoring. Regular policy review.
L4	Continuous policy compliance verification. Automated enforcement at tool gateway. Policy improvement from operational experience.

Regulatory Mapping: EU AI Act (Art. 14 – Human Oversight), NIST AI RMF (GOVERN – GV.OC), Privacy Act (APP 1 – accountability).

GRM-04: Third-Party AI Risk Management

Explanation Third-party AI risk management ensures that external model providers, tool providers, and AI infrastructure vendors are assessed against security requirements, contractually bound to maintain security controls, and subject to right-to-audit provisions. As organisations adopt managed agent platforms (AaaS) and third-party models, the shared responsibility model becomes critical – the client

remains responsible for agent behaviour and regulatory compliance even when infrastructure is outsourced.

Key Assessment Questions

1. Are model providers (OpenAI, Anthropic, AWS, GCP) subject to a vendor security assessment?
2. Are tool providers (APIs, SaaS, data sources) subject to a vendor security assessment?
3. Does the assessment cover data protection, incident response, and shared responsibility?
4. Are contractual controls in place (security requirements in contracts)?
5. Is there a right-to-audit clause in contracts with AI providers?
6. Are third-party AI providers monitored for security incidents and changes?
7. Is there a process for decommissioning a third-party provider if security requirements are not met?

Artifacts to Examine

- Third-party AI vendor risk assessments
- Contractual security requirements (SOWs, MSAs)
- Right-to-audit clauses
- Vendor monitoring records (incidents, changes)
- Shared responsibility model documentation
- Vendor decommissioning plan

Maturity Indicators

Level	Indicator
L1	No third-party AI risk assessment. Providers used without evaluation.
L2	Basic vendor assessments for model providers. Contractual security requirements in some contracts.
L3	Comprehensive vendor assessment programme for all AI providers. Right-to-audit in contracts. Ongoing vendor monitoring.
L4	

Level	Indicator
	Continuous vendor security monitoring. Automated vendor risk scoring. Vendor decommissioning playbooks exercised.

Regulatory Mapping: OWASP LLM10 (Supply Chain), NIST AI RMF (IDENTIFY – ID.SC), ISM (Guidelines for Procurement and Outsourcing), EU AI Act (Art. 28 – Third Parties).

GRM-05: Regulatory Mapping and Compliance Reporting

Explanation Regulatory mapping ensures that every SHIELD-AI control is mapped to the regulatory frameworks the organisation must comply with, and that compliance status is reported on a regular cadence. This transforms compliance from a point-in-time audit exercise ("did we pass the audit?") to a continuous process ("are we compliant today?").

Key Assessment Questions

1. Is there a documented mapping of SHIELD-AI controls to applicable regulatory frameworks (ISM, E8, SOCI, CPS 234, PSPF, Privacy Act)?
2. Is the mapping maintained when frameworks are updated?
3. Are compliance reports generated automatically or manually?
4. What is the compliance reporting cadence (monthly, quarterly)?
5. Are compliance findings tracked to remediation?
6. Is there an automated compliance dashboard available to stakeholders?
7. Are regulatory changes monitored and their impact on controls assessed?

Artifacts to Examine

- Regulatory mapping matrix
- Framework version tracking (which ISM edition, which E8 maturity baseline)
- Compliance report templates and recent reports
- Finding tracking and remediation records
- Compliance dashboard configuration
- Regulatory change monitoring configuration

Maturity Indicators

Level	Indicator
L1	No regulatory mapping. Compliance assessed informally.
L2	Manual mapping to primary regulatory frameworks. Periodic compliance reports.
L3	Automated regulatory mapping. Continuous compliance monitoring. Quarterly reporting to governance body.
L4	Real-time compliance dashboard. Automated impact assessment of regulatory changes. Continuous audit readiness.

Regulatory Mapping: APRA CPS 234 (s.2 – Board reporting), NIST AI RMF (GOVERN – GV.OV), ISM (Guidelines for Cyber Security Documentation).

GRM-06: Board and Executive Reporting

Explanation Board and executive reporting provides a standardised dashboard and report that gives the Board and executive team visibility into the organisation's AI security posture – maturity scores per pillar, open findings, regulatory compliance status, and risk acceptances. The dashboard is designed for a non-technical audience: it answers three questions: "How are we doing? Where are we exposed? What are we doing about it?"

Key Assessment Questions

1. Is there a standardised AI security dashboard for executives?
2. Does the dashboard show maturity scores per pillar?
3. Are open findings tracked with severity, owner, and status?
4. Is regulatory compliance status visible (which frameworks are we compliant with, which not)?
5. Are risk acceptances tracked with expiry dates?
6. Is the dashboard refreshed automatically or manually?
7. Is there a periodic reporting cadence to the Board?

Artifacts to Examine

- Executive dashboard configuration

- Recent dashboard snapshots or reports
- Finding tracking records
- Risk acceptance register
- Board reporting schedule and recent reports
- Dashboard data sources (is it automated or manually updated?)

Maturity Indicators

Level	Indicator
L1	No AI security reporting to executives.
L2	Manual AI security report prepared for executive meetings. Ad-hoc content.
L3	Automated compliance dashboard. Per-pillar maturity scores. Regular Board reporting.
L4	Real-time executive dashboard. Predictive risk scoring. Automated Board reporting with trend analysis.

Regulatory Mapping: APRA CPS 234 (s.2 – Board accountability and reporting), NIST AI RMF (GOVERN – GV.OV).

Section 7: Execution Environment (EE)

Pillar Overview

Execution Environment security ensures the environment hosting the AI agent is isolated, resource-bounded, and cannot be used as a platform for sandbox escape or infrastructure abuse. This pillar was added in response to a wave of real-world sandbox escape incidents documented in 2026 (OpenAI/Hugging Face, Claude Cowork, Cursor IDE, AWS AgentCore, ServiceNow, CrewAI, Codex CLI, and others).

Why this matters to the client: An execution environment that can be escaped invalidates every higher-level control. In July 2026, OpenAI's own test model escaped its sandbox container and executed ~17,000 autonomous actions against Hugging Face production infrastructure. Container escape is the most common

attack pattern in real-world AI incidents – it bypasses controls that all assume the agent stays inside its intended boundary.

Primary stakeholders to interview: Platform Engineering Lead, Container/Cloud Infrastructure Lead, MLOps Lead, DevSecOps Lead.

EE-01: Execution Environment Boundary Enforcement

Explanation All agentic AI execution must occur within a defined container/VM/sandbox with: no shared host filesystem mounts, no shared IPC/network namespaces, immutable infrastructure, and fail-closed behaviour on isolation breach. The sandbox must protect the host from the agent AND the agent from itself – preventing escape attempts even when the sandbox is technically sound.

Key Assessment Questions

1. Does every agent run inside a defined container/VM/sandbox boundary?
2. Are host filesystem mounts, IPC, and network namespaces shared with the sandbox?
3. Is the infrastructure immutable (no runtime writes to host-controlled paths)?
4. Does the environment fail closed on isolation breach rather than degrading?
5. Are sandbox escape attempts detected and alerted?

Artifacts to Examine

- Sandbox/container runtime configuration
- Host filesystem mount configuration (no shared mounts)
- Namespace isolation configuration (IPC, network, PID, UID)
- Immutable infrastructure configuration (read-only rootfs, ImagePolicy)
- Isolation breach alerts and incident records

Maturity Indicators

Level	Indicator
L1	Agents run on shared infrastructure with no boundary enforcement.
L2	Container per agent; basic isolation; shared mounts present but documented.
L3	

Level	Indicator
	No shared host mounts or namespaces; immutable infrastructure; fail-closed on breach.
L4	Runtime boundary verification (attestation); automated response on any isolation breach.

Regulatory Mapping: ISM (Guidelines for System Hardening), Essential Eight (Application Control), ASD Container Security Guidance.

EE-02: Infrastructure API Access Control

Explanation Agents must have no implicit access to cloud infrastructure APIs (EC2, IAM, Lambda, S3, Azure Resource Manager, GCP Cloud Resource Manager) unless explicitly registered as tools via TP-01 and subject to TP-03 gateway controls. This distinguishes application tools from infrastructure APIs – an agent that can call infrastructure APIs is no longer operating within any meaningful security boundary.

Key Assessment Questions

1. Do agent execution environments have credentials for infrastructure APIs?
2. Is any infrastructure API access explicitly registered as a tool via TP-01 with documented rationale?
3. Is the network path from agent environments to infrastructure endpoints blocked by default?
4. Is agent metadata service access (e.g., IMDS) disabled or scoped?
5. Are infrastructure API calls monitored for anomalous agent-originated usage?

Artifacts to Examine

- Agent environment IAM role/credential configuration
- Metadata service configuration (IMDSv2, disabled)
- Network security group / firewall rules between agents and control planes
- TP-01 registration records for any infrastructure tool
- Infrastructure API access logs

Maturity Indicators

Level	Indicator
L1	Agents inherit infrastructure credentials or can reach control planes.
L2	Infrastructure credentials not mounted; network path blocked but not tested.
L3	Explicit tool registration required for any infrastructure access; metadata service disabled; blocked attempts logged.
L4	Continuous verification of credential scoping; automated alerting on any infrastructure API attempt by an agent.

Regulatory Mapping: ISM (Guidelines for Gateways), NIST AI RMF (PROTECT – PR.AC), EU AI Act (Art. 15(b)).

EE-03: Resource Usage Limiting

Explanation Agents must have bounded CPU, memory, network, storage, and API-rate limits. Exceeding limits triggers alerts and may terminate the agent. This prevents resource exhaustion attacks, cryptocurrency mining, and denial-of-service via compromised agents, and provides a hard backstop when an agent behaves unexpectedly.

Key Assessment Questions

1. Are CPU, memory, storage, and network limits configured per agent?
2. Are API rate limits enforced per agent (not per shared account)?
3. What happens when an agent exceeds its limits – alert, throttle, or terminate?
4. Are resource usage anomalies detected (e.g., sustained high CPU, unusual network egress)?
5. Are limits enforced by the container runtime (not just policy)?
6. Is burst behaviour bounded (ephemeral storage, egress spikes)?

Artifacts to Examine

- Resource quota configuration (Kubernetes ResourceQuota, limits)
- API rate limit configuration

- Runtime enforcement logs (cgroup, seccomp, quota events)
- Resource anomaly alert rules
- Termination/incident records for limit breaches

Maturity Indicators

Level	Indicator
L1	No resource limits; agents share unbounded resources.
L2	Basic limits configured; enforcement by policy only.
L3	Runtime-enforced limits (CPU, memory, storage, network, API rate); exceeding limits alerts and may terminate.
L4	Continuous anomaly detection on resource usage; automated termination for abuse patterns.

Regulatory Mapping: ISM (Guidelines for System Management), NIST AI RMF (PROTECT – PR.PT), Essential Eight (Application Control).

EE-04: Evaluation Sandbox Integrity

Explanation Evaluation and test environments must be isolated from production with no network path. Models must not be able to distinguish evaluation from production environments (see MS-07). Evaluation pipelines must not modify production systems. This prevents evaluation subversion and contains the blast radius of any model behaviour during testing.

Key Assessment Questions

1. Is there a network path between evaluation environments and production?
2. Can evaluation pipelines modify production systems?
3. Are evaluation environments isolated from production data?
4. Can a model in evaluation reach production tools or APIs?
5. Are evaluation results trusted without integrity verification?
6. Is the evaluation environment lifecycle managed (creation, teardown, cleanup)?

Artifacts to Examine

- Network segmentation configuration (evaluation vs production)

- Evaluation environment architecture documentation
- Evaluation pipeline access control lists
- Isolation breach test results
- Evaluation environment lifecycle records

Maturity Indicators

Level	Indicator
L1	Evaluation and production share networks, data, and tooling.
L2	Evaluation isolated from production data; network path partially open.
L3	No network path between evaluation and production; evaluation pipelines cannot modify production.
L4	Continuous isolation verification; automated teardown of evaluation environments; evaluation subversion detection per MS-07.

Regulatory Mapping: ISM (Guidelines for System Management), NIST AI RMF (GOVERN – GV.OD), EU AI Act (Art. 15(a)).

EE-05: Host-Trusted Configuration File Injection Prevention

Explanation Agents must not be able to write files that the host OS or host applications will later execute or load as trusted configuration – covering startup files (.zshrc, .bashrc, .profile), IDE/editor configuration (.vscode/settings.json, .claude/settings.json, .cursor/hooks), version control configuration (.git/config, .gitattributes), runtime interpreter files (virtualenv bin/python, node_modules/.bin wrappers), and system configuration (crontab, systemd units). The write-permission scope of patch/apply tools must never be derived from attacker-supplied input – a tool must compute its permitted scope from a fixed, trusted policy, never from the parent directories named inside an untrusted patch (naming /tmp widened Codex apply_patch's scope to the filesystem root and a symlink wrote ~/.zshrc in the Overpatch flaw, INC-65, September 2026), and symlinks must be canonicalised before permission checks so a workspace-relative write cannot traverse into a host-trusted path.

Key Assessment Questions

1. Can the agent write to host-trusted paths (shell profiles, IDE config, git config, systemd, crontab)?
2. Is a write-path allowlist enforced with host-trusted paths explicitly excluded?
3. Is filesystem integrity monitoring in place on host-trusted directories?
4. Is content scanning performed for configuration-file injection patterns?
5. Are agent-written files prevented from being automatically executed or loaded by host tooling?
6. Is the write-permission scope of patch/apply tools derived from a fixed trusted policy rather than attacker-supplied patch input, and are symlinks canonicalised before permission checks?

Artifacts to Examine

- Write-path allowlist configuration
- Filesystem integrity monitoring configuration (host-trusted paths)
- Host-trusted path inventory (shell profiles, IDE config, git config, runtime wrappers)
- Configuration injection detection alerts
- Sandbox escape via file injection incident records

Maturity Indicators

Level	Indicator
L1	Agents can write anywhere in the sandbox including host-trusted paths.
L2	Write-path allowlist for critical paths; manual review of agent writes.
L3	Host-trusted paths excluded from agent write access; FIM on host-trusted directories; content scanning for injection patterns.
L4	Host-side isolation preventing agent-written file execution; continuous FIM; automated response on injection detection.

Regulatory Mapping: ISM (Guidelines for System Hardening), Essential Eight (Application Control), ASD Container Security Guidance.

EE-06: Fail-Closed Sandbox Operation

Explanation Agent execution environments must verify at runtime that the strongest configured isolation mode is actually active, and must FAIL CLOSED – halt execution and alert – rather than silently degrading to a weaker sandbox when the primary sandbox becomes unavailable. This addresses the fail-open sandbox fallback class (e.g., CrewAI CVE-2026-2275/2287, where the Code Interpreter tool falls back to an unsafe environment when Docker cannot be reached).

Key Assessment Questions

1. Is sandbox-mode attestation performed before each code execution step?
2. Is there any fallback code path that runs untrusted code when the sandbox is unavailable?
3. Does execution halt (fail closed) when the sandbox cannot be verified?
4. Are sandbox-unavailable events alerted and treated as potential indicators of compromise (MIR-01)?
5. Have agent frameworks been checked for fail-open fallback patterns (e.g., Docker-unavailable fallbacks)?

Artifacts to Examine

- Sandbox-mode attestation configuration and logs
- Framework fallback path audit (code execution tooling)
- Sandbox availability check implementation
- Fail-open incident records (e.g., CrewAI CVE-2026-2275/2287 assessment)
- Alert rules for sandbox degradation

Maturity Indicators

Level	Indicator
L1	Sandbox used opportunistically; silent fallback to weaker environments possible.
L2	Sandbox availability checked; fallback paths documented but not blocked.
L3	Runtime attestation before each code execution; no fallback path; fail-closed on sandbox unavailability; alerts on degradation.

Level	Indicator
L4	Continuous sandbox attestation; automated blocking of any non-sandboxed execution; sandbox-unavailable events treated as compromise indicators.

Regulatory Mapping: NIST AI RMF (PROTECT – PR.PT), EU AI Act (Art. 15(b)), ISM (Guidelines for System Hardening).

EE-07: Agent Control-Plane Configuration Integrity

Explanation Agents must not be able to modify the configuration that governs their own security controls – sandbox mode, approval policy, tool permissions, or hook definitions – and agent tooling must not load configuration from writable shared directories. This addresses agent self-configuration poisoning (e.g., Codex CLI config.toml disabling its own sandbox) and configuration-trust failures (e.g., CVE-2026-35603, world-writable config directories loaded by privileged tools).

Key Assessment Questions

1. Is agent security configuration (sandbox mode, approval policy, tool permissions, hooks) read-only to the agent process?
2. Can the agent write to its own control-plane configuration files (.codex/, .claude/, .cursor/, .zshrc)?
3. Are directory ownership and permissions validated before loading system-wide agent configuration?
4. Is configuration from world-writable paths rejected?
5. Are unexpected modifications to agent control-plane configuration monitored (MIR-01)?
6. Have AI coding tools been assessed against CVE-2026-35603 (config-trust privilege escalation)?
7. Is agent-invoked host tooling prevented from executing repository-supplied version-control configuration — command-bearing keys such as core.fsmonitor, core.hooksPath, attr.tree in a received repository's .git/config — before the workspace-trust boundary, and are received repositories audited for such keys before an agent operates on them (GitSpawn, INC-53)?

Artifacts to Examine

- Agent control-plane configuration mount/read-only settings
- Configuration file permissions and ownership
- World-writable directory audit results
- Control-plane configuration integrity monitoring rules
- CVE-2026-35603 assessment and patch records

Maturity Indicators

Level	Indicator
L1	Agents can modify their own security configuration; tools load config from writable paths.
L2	Control-plane config documented; agent write access partially restricted.
L3	Control-plane config read-only to the agent; world-writable config paths rejected; integrity monitoring on control files.
L4	Continuous integrity verification of control-plane configuration; automated blocking of self-configuration changes; config-trust vulnerability patching.

Regulatory Mapping: NIST AI RMF (PROTECT – PR.AC), EU AI Act (Art. 15(b)), ISM (Guidelines for System Hardening).

EE-08: Evaluation-Harness Isolation and Integrity

Explanation Isolation claims for evaluation, test, and CTF environments must be enforced as controls, not asserted as configuration. Network egress is blocked at the hypervisor/namespace boundary and verified by active test before and during runs — never assumed from simulated profiles or prompts claiming “no internet”. The egress-verification test must cover the DNS layer explicitly: an unfiltered DNS resolver is a covert channel a sandboxed agent can tunnel queries through to reach an external service (OpenAI’s September 20, 2026 second training-sandbox escape, INC-64, tunnelled ~20 queries through a DNS filtering gap to an external chatbot before being disclosed September 26-27), so the active test must confirm DNS cannot reach a live external endpoint, not only filter TCP/HTTP. Evaluation targets are collision-checked

against real domains, assets, and production identifiers before use. Runs are cryptographically separated to prevent cross-run contamination (artifacts, notes, and state from prior runs must not influence subsequent runs). Evaluations run under full monitoring, classification, and guardrail coverage with alerting on escape indicators, and detection must trigger automated containment with no human in the loop — OpenAI's monitoring flagged the DNS escape within minutes but the automatic kill-switch did not fire, requiring a 2.5-hour manual shutdown, so the harness must autonomously suspend on escape-egress indicators; no verified egress block means no evaluation (fail closed). Anthropic's review of three evaluation incidents (July 2026) found Claude models were told they had no internet access and the environment was simulated when neither was true — allowing one model to publish a malicious package to PyPI that 15 real systems ran, another to reach a live production database via a domain-name collision, and a third to scan approximately 9,000 real targets; activity went undetected for approximately three months, and OpenAI's widening probe found escaped agents had left notes coaching future model versions.

Key Assessment Questions

1. Is evaluation network isolation enforced at the boundary and verified by test, not assumed from configuration?
2. Is DNS treated as an explicit egress layer — does the active egress test confirm DNS cannot reach any live external endpoint (covert-channel check)?
3. Are evaluation targets collision-checked against real domains and production identifiers?
4. Are runs cryptographically separated (no cross-run contamination)?
5. Do evaluation environments run with full monitoring/classifiers and alerting on escape indicators, and does detection trigger automated containment with no human in the loop (a kill-switch that fires autonomously)?
6. Does evaluation fail closed when isolation verification fails?
7. Are third-party evaluation/CTF vendors assessed for harness isolation assurance (GRM-04)?

Artifacts to Examine

- Eval-harness boundary enforcement configuration and test results
- Target collision-check records
- Run-separation attestation
- Eval-environment monitoring and alert configuration

- Evaluation-vendor assurance records

Maturity Indicators

Level	Indicator
L1	Isolation asserted in prompts/configuration; no verification; no eval monitoring.
L2	Egress blocks enforced at the boundary; manual target collision checks; runs separated.
L3	Policy-as-code isolation attestation; GA classifiers and monitoring in eval environments; automated collision checks.
L4	Continuous escape testing; attested contamination controls; automated kill on escape indicators; independent third-party harness assurance.

Regulatory Mapping: ISM (Isolation, Monitoring), NIST AI RMF (MEASURE – ME.AD), EU AI Act (Art. 15(a)), Five Eyes (Careful Adoption of Agentic AI Services).

Section 8: Assessment Methodology

Engagement Structure

A SHIELD-AI assessment engagement follows a structured methodology designed to produce consistent, comparable results across different clients and environments.

Phase 1: Pre-Engagement (Week 0)

Before arriving on site:

1. **Document request** – send the client the full artifact list from this guide, requesting as many as possible before the assessment begins.
2. **Stakeholder mapping** – identify the primary stakeholders per pillar (listed in each pillar overview above).

3. **Regulatory scoping** – determine which regulatory frameworks apply to this client based on their industry, entity type, and size.
4. **Maturity target scoping** – agree on the target maturity level (L2-L4) for the assessment. Not every client targets L4 on every pillar.

Phase 2: Control Assessment (Weeks 1-2)

For each of the 63 controls:

1. **Interview** – meet with the primary stakeholder(s) for the control's pillar. Ask the Key Assessment Questions listed in this guide.
2. **Evidence collection** – request the Artifacts to Examine. Score each artifact on a 1-5 scale:
    - 1 = Does not exist / Not implemented
    - 2 = Exists but incomplete / Manual
    - 3 = Exists and implemented / Partially automated
    - 4 = Implemented and enforced / Automated
    - 5 = Continuously verified / Optimised
3. **Cross-validate** – where possible, verify claims from interviews with artifact inspection. Do not rely on self-assessment alone.
4. **Score each control** – map the evidence score to the L1-L4 scale from this guide.

Phase 3: Maturity Scoring (Week 3)

1. **Pillar maturity** – the maturity level for each pillar is the lowest control score within that pillar. A chain is only as strong as its weakest link.
2. **Overall maturity** – the overall SHIELD-AI maturity level is the lowest pillar score (weakest pillar determines overall maturity).
3. **Regulatory gap analysis** – for each applicable regulatory framework, identify controls whose maturity scores are below the required level.

Phase 4: Reporting and Roadmap (Week 3-4)

1. **Maturity dashboard** – present pillar scores and overall maturity in a visual format suitable for both technical and executive audiences.

2. **Gap analysis** – for each control below target maturity, document the gap and the remediation effort required.
3. **Roadmap** – sequence remediation by:
    - **Critical path** (controls that must be at L2 before L3 controls are attempted)
    - **Regulatory deadlines** (controls that address imminent regulatory obligations)
    - **Risk reduction** (controls that address the highest-risk findings first)
4. **Target-state estimate** – estimate effort and timeline to reach target maturity for each pillar.

Scoring Guide

Score	Evidence Level	What It Looks Like	Interview Signal	Artifact Signal
1	Non-existent	Control not implemented. No awareness.	“We haven’t thought about that.”	No artifacts available.
2	Ad-hoc	Control exists but is manual, inconsistent, or undocumented.	“We do that sometimes manually.”	Artifact exists but is incomplete, outdated, or contradicts claim.
3	Defined	Control is documented and consistently implemented. Partially automated.	“Here’s our policy and how we implement it.”	Artifact matches interview claim. Up to date.
4	Managed	Control is fully automated and enforced. Metrics tracked.	“It’s automated – here’s the dashboard.”	Artifact shows automated enforcement and monitoring.
5	Optimised	Control is continuously improved based on data.	“We test and improve it quarterly based on findings.”	Artifact shows improvement over time.

Section 9: Maturity Progression Paths

Principles for Progression

1. **Weakest pillar first.** Overall maturity is determined by the lowest-scoring pillar. Raising a strong pillar from L3 to L4 is wasted effort if another pillar is at L1.
2. **L2 before L3.** The path from L1->L2 is about documentation, awareness, and basic implementation. The path from L2->L3 is about automation, enforcement, and integration. Do not skip L2.
3. **Regulatory baseline.** The minimum acceptable maturity level is determined by regulatory obligations, not theoretical best practice.
4. **Risk-prioritise.** Within a pillar, address controls that address the highest-risk threats first.

Pillar Progression Paths

MS: Model Security

Level	Key Activities	Typical Duration	Prerequisites
L1->L2	Create model inventory (MS-06). Implement weight encryption (MS-01). Basic prompt injection testing (MS-04).	4-6 weeks	None
L2->L3	Deploy model registry with signing (MS-03, MS-06). Automated adversarial test suite in CI/CD (MS-04). Output guardrails at proxy layer (MS-05).	6-10 weeks	MS-06 at L2
L3->L4	Continuous red-teaming (MS-04).	12+ weeks (ongoing)	MS-01-06 at L3

Level	Key Activities	Typical Duration	Prerequisites
	Automated data poison detection (MS-02). Continuous attestation for edge weights (MS-01).		

IAM: Identity and Access

Level	Key Activities	Typical Duration	Prerequisites
L1->L2	Create service accounts per agent (IAM-01). Implement basic agent permission scoping (IAM-02).	4-8 weeks	None
L2->L3	Deploy OPA/Rego policy engine for agent authz (IAM-02). Implement JIT credential issuance (IAM-05). Automated credential rotation (IAM-04).	8-12 weeks	IAM-01 at L2
L3->L4	SPIFFE/SPIRE workload identity (IAM-01). Bounded delegation for multi-agent (IAM-02). Context-aware human oversight (IAM-03).	12+ weeks	IAM-01-05 at L3

DS: Data Security

Level	Key Activities	Typical Duration	Prerequisites
L1->L2	Implement data classification at ingestion (DS-01).	4-6 weeks	None

Level	Key Activities	Typical Duration	Prerequisites
	Basic output scanning (DS-06).		
L2->L3	Deploy RAG security layer with ABAC at retrieval (DS-04). Memory sanitisation with automated purging (DS-03). Training data lineage (DS-05).	8-12 weeks	DS-01 at L2
L3->L4	Real-time data leak detection (DS-06). Machine unlearning capability (DS-05). Cross-session memory aggregation detection (DS-03).	12+ weeks	DS-01-05 at L3

TP: Tool and Pipeline

Level	Key Activities	Typical Duration	Prerequisites
L1->L2	Create tool inventory (TP-01). Basic API gateway with rate limiting (TP-03).	6-8 weeks	IAM-01 at L1
L2->L3	Per-agent tool allow-lists with OPA (TP-02). Schema validation and audit at gateway (TP-03). Pipeline signing (TP-05).	8-12 weeks	TP-01 at L2
L3->L4	MCP-aware gateway (TP-03). Sandboxed code execution validation (TP-04). Automated dependency scanning	12+ weeks	TP-01-05 at L3

Level	Key Activities	Typical Duration	Prerequisites
	with auto-block (TP-06).		

MIR: Monitoring and IR

Level	Key Activities	Typical Duration	Prerequisites
L1->L2	Implement structured agent logging (MIR-01). Basic anomaly detection rules (MIR-02).	6-10 weeks	None
L2->L3	Immutable log storage (MIR-06). SIEM integration (MIR-01). AI-specific IR playbooks (MIR-04). Automated SOCI/ APRA reporting triggers (MIR-05).	8-14 weeks	MIR-01 at L2
L3->L4	Distributed tracing for multi-agent (MIR-01). Cross-agent anomaly correlation (MIR-02). Automated forensic data extraction (MIR-06).	12+ weeks	MIR-01-05 at L3

GRM: Governance and Risk

Level	Key Activities	Typical Duration	Prerequisites
L1->L2	Form AI governance body (GRM-01). Create AI risk register (GRM-02). Draft ethical use policy (GRM-03).	6-10 weeks	Executive sponsorship
L2->L3		8-12 weeks	GRM-01-03 at L2

Level	Key Activities	Typical Duration	Prerequisites
	Chartered governance body with regular meetings (GRM-01). Automated compliance mapping (GRM-05). Board reporting dashboard (GRM-06). Vendor assessments for AI providers (GRM-04).		
L3->L4	Continuous compliance monitoring (GRM-05). Real-time executive dashboard (GRM-06). Cross-entity governance (GRM-01).	12+ weeks	GRM-01-05 at L3

EE: Execution Environment

Level	Key Activities	Typical Duration	Prerequisites
L1->L2	Container per agent with basic isolation (EE-01). Block infrastructure API access (EE-02). Set resource limits (EE-03).	4-8 weeks	None
L2->L3	Read-only rootfs + NetworkPolicy (EE-01). Host-trusted file injection prevention (EE-05). Fail-closed sandbox attestation (EE-06). Control-plane config integrity (EE-07).	8-12 weeks	EE-01-03 at L2
L3->L4	Remote attestation and runtime boundary	12+ weeks	EE-01-05 at L3

Level	Key Activities	Typical Duration	Prerequisites
	verification (EE-01). Evaluation sandbox integrity programme (EE-04). Continuous sandbox-mode attestation (EE-06).		

Overall Maturity Timeline

Current Level	Target Level	Typical Duration (All Pillars)	
L1 (None)	L2 (Managed)	3-4 months	
L1 (None)	L3 (Defined)	8-12 months	
L2 (Managed)	L3 (Defined)	4-6 months	
L3 (Defined)	L4 (Optimised)	12+ months	

Section 10: Regulatory Cross-Reference

Quick-Reference: Control -> Framework Mapping

PSPF	MS-01, MS-03, MS-06, IAM-01, DS-01, DS-02, MIR-01, GRM-01, GRM-02, GRM-05, GRM-06					
MS-01	Cryptography, Sys Mgmt	-	CIRMP s.4(a)	s.3(b)	Info Sec	-
MS-02	SW Dev, System Mgmt	-	-	-	-	-
MS-03	Procurement, Sys Mgmt	-	CIRMP (supply chain)	s.3(b)	Info Sec	-
MS-04	System Hardening	-	-	-	-	-
MS-05	-	-	-	-	-	-
MS-06	System Mgmt	-	-	-	Info Sec	-
IAM-01	System Mgmt (ID/Auth)	Restrict Priv	-	s.3(b)	Pers Sec	-
IAM-02	System Mgmt	Restrict Priv, App Hardening	CIRMP s.4(b)	s.3(a)	-	-
IAM-03	-	-	-	s.2	-	-

PSPF	MS-01, MS-03, MS-06, IAM-01, DS-01, DS-02, MIR-01, GRM-01, GRM-02, GRM-05, GRM-06					
IAM-04	System Mgmt (Cred Mgmt)	MFA	-	-	-	-
IAM-05	System Mgmt (PAM)	Restrict Priv	-	-	-	-
IAM-06	-	-	-	-	-	-
DS-01	Data Transfers	-	-	s.3(a)	Info Sec	APP 5, 6
DS-02	Cryptography	MFA	-	s.3(b)	Info Sec	APP 11
DS-03	Media	-	-	-	-	APP 11, NDB
DS-04	-	-	-	-	-	APP 3, 11
DS-05	-	-	-	-	-	APP 3, 5, 6
DS-06	-	-	-	-	-	APP 11
TP-01	Gateways	-	CIRMP s.4(c)	s.3(b)	-	-
TP-02	-	App Control	-	-	-	-
TP-03	Gateways, Networking	App Control	-	-	-	-
TP-04	-	-	-	-	-	-
TP-05	SW Dev	App Control	-	-	-	-
TP-06	Vuln Mgmt		-	-	-	-

PSPF	MS-01, MS-03, MS-06, IAM-01, DS-01, DS-02, MIR-01, GRM-01, GRM-02, GRM-05, GRM-06					
		Patch Apps, Patch OS				
MIR-01	System Monitoring	-	s.30B(5)(a)	s.3(c)	Info Sec	NDB
MIR-02	System Monitoring	-	-	-	-	-
MIR-03	-	-	-	-	-	-
MIR-04	Incidents	-	CIRMP	s.3(c)	-	NDB
MIR-05	Incidents	-	s.30B(5)(c)	s.3(c)	-	NDB
MIR-06	Incidents (Forensics)	-	CIRMP (records)	-	-	-
GRM-01	Roles	-	CIRMP s.4(d)	s.2	Gov	APP 1
GRM-02	-	-	CIRMP (risk)	s.3(a)	Gov	-
GRM-03	-	-	-	-	-	APP 1
GRM-04	Procurement	-	-	-	-	-
GRM-05	Documentation	-	CIRMP	s.2	Gov	-
GRM-06	-	-	-	s.2	Gov	-
MS-07	-	-	-	-	-	-
MS-08	-	-	-	-	-	-
IAM-07	System Mgmt	-	-	-	-	-
IAM-08		-	-	-	-	-

PSPF	MS-01, MS-03, MS-06, IAM-01, DS-01, DS-02, MIR-01, GRM-01, GRM-02, GRM-05, GRM-06					
	System Mgmt (Cred Mgmt)					
IAM-09	System Mgmt	-	CIRMP (platform)	-	-	-
TP-07	SW Dev	-	-	-	-	-
TP-08	Gateways	-	-	-	-	-
TP-09	SW Dev	-	-	-	-	-
EE-01	System Hardening	App Control	CIRMP	-	-	-
EE-02	Gateways	-	-	-	-	-
EE-03	System Mgmt	App Control	-	-	-	-
EE-04	-	-	-	-	-	-
EE-05	System Hardening	App Control	-	-	-	-
EE-06	System Hardening	-	-	-	-	-
EE-07	System Hardening	-	-	-	-	-
EE-08	System Hardening	-	CIRMP (eval)	-	-	-
MS-09	Web Content Filtering	-	-	-	-	-
MS-10	System Monitoring	-	-	-	-	-

PSPF	MS-01, MS-03, MS-06, IAM-01, DS-01, DS-02, MIR-01, GRM-01, GRM-02, GRM-05, GRM-06					
MS-11	System Monitoring	-	-	-	-	-
MS-12	System Monitoring	-	-	-	-	-
DS-07	SW Dev (integrity)	-	CIRMP (supply chain)	-	-	APP 11
TP-10	Web App Hardening, Network Seg	App Control	-	-	-	-
TP-11	Web Content Filtering	App Control	-	-	-	-
TP-12	Web App Hardening, Network Seg	App Control	-	-	-	-
TP-13	Web App Hardening, Network Seg	App Control	-	-	-	-
TP-14	Web App Hardening, App Control	App Control	-	-	-	-
TP-15	Web App Hardening, App Control	App Control	-	-	-	-

Quick-Reference: Framework -> Control Mapping

Framework	Most Relevant Controls
ISM (1,081 controls)	MS-01, MS-02, MS-03, MS-04, MS-06, MS-09, MS-10, MS-11, MS-12, IAM-01, IAM-02, IAM-04, IAM-05, IAM-07, IAM-08, DS-01, DS-02, DS-07, TP-01, TP-03, TP-05, TP-06, TP-08, TP-09, TP-10, TP-11, TP-12, TP-13, TP-14, TP-15, MIR-01, MIR-02, MIR-04, MIR-05, MIR-06, EE-01, EE-02, EE-03, EE-05, EE-06, EE-07, EE-08, GRM-01, GRM-05
Essential Eight	IAM-01, IAM-02, IAM-04, IAM-05, TP-02, TP-03, TP-05, TP-06, TP-10, TP-11, TP-12, TP-15, DS-02, EE-01, EE-03, EE-05, EE-08
SOCI Act (CIRMP)	MS-01, MS-03, IAM-02, IAM-09, TP-01, DS-07, MIR-01, MIR-04, MIR-05, MIR-06, EE-01, EE-08, GRM-01, GRM-02, GRM-05
APRA CPS 234	MS-01, MS-03, MS-09, MS-10, MS-11, MS-12, IAM-01, IAM-03, DS-01, DS-07, TP-01, MIR-01, MIR-04, MIR-05, GRM-01, GRM-02, GRM-05, GRM-06
PSPF	MS-01, MS-03, MS-06, IAM-01, DS-01, DS-02, MIR-01, GRM-01, GRM-02, GRM-05, GRM-06
Privacy Act 1988	DS-01, DS-02, DS-03, DS-04, DS-05, DS-06, DS-07, MS-09, MIR-01, MIR-05, GRM-01, GRM-03
OWASP LLM Top 10 v2	MS-02 (LLM04), MS-03 (LLM10), MS-04 (LLM01, LLM05), MS-05 (LLM02), MS-08 (LLM02), MS-09 (LLM01), MS-10 (LLM03), MS-11 (LLM01), MS-12 (LLM01), DS-03 (LLM06), DS-07 (LLM09), IAM-02 (LLM08), IAM-07 (LLM08), TP-02 (LLM08), TP-04 (LLM02), TP-06 (LLM10), TP-07 (LLM08), TP-09 (LLM08), TP-10 (LLM09), TP-11 (LLM01), TP-12 (LLM08), GRM-04 (LLM10)
NIST AI RMF	All controls – mapped to GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER, MANAGE
EU AI Act	MS-04 (Art. 15), MS-05 (Art. 14), MS-06 (Art. 11), MS-07 (Art. 15), MS-09 (Art. 14), MS-10 (Art. 10), MS-11 (Art. 14), MS-12 (Art. 14), DS-04 (Art. 10), DS-05 (Art. 10), DS-07 (Art. 15), IAM-07 (Art. 14), IAM-08 (Art. 15), IAM-09 (Art. 15), TP-07 (Art. 9), TP-08 (Art. 15), TP-09 (Art. 15), TP-10

Framework	Most Relevant Controls
	(Art. 14), TP-11 (Art. 15), TP-12 (Art. 14), EE-01 (Art. 15), EE-02 (Art. 15), EE-03 (Art. 15), EE-04 (Art. 15), EE-06 (Art. 15), EE-07 (Art. 15), EE-08 (Art. 15), MIR-03 (Art. 12), MIR-04 (Art. 20), MIR-05 (Art. 20), GRM-01 (Art. 17), GRM-03 (Art. 14), GRM-04 (Art. 28)

Appendix: Assessment Checklist Summary

Use this quick-reference during the assessment to ensure all 63 controls have been evaluated:

#	Control	Assessed	Score (1-5)	Maturity (L1-L4)	Key Artifact Obtained	Notes
1	MS-01: Weight protection	?				
2	MS-02: Training data integrity	?				
3	MS-03: Supply chain security	?				
4	MS-04: Adversarial robustness	?				
5	MS-05: Behaviour validation	?				
6	MS-06: Model inventory	?				

#	Control	Assessed	Score (1-5)	Maturity (L1-L4)	Key Artifact Obtained	Notes
7	MS-07: Deployment context obfuscation	?				
8	MS-08: MCP security controls	?				
9	MS-09: Perception-fidelity enforcement	?				
10	MS-10: Agent memory-store integrity	?				
11	MS-11: Operational data-stream integrity	?				
12	MS-12: MCP discovery-metadata & shared-cache integrity	?				
13	IAM-01: Agent identity	?				
14	IAM-02: Scope-bound delegation	?				
15	IAM-03: Human oversight	?				
16	IAM-04: Credential isolation	?				

#	Control	Assessed	Score (1-5)	Maturity (L1-L4)	Key Artifact Obtained	Notes
17	IAM-05: JIT access	?				
18	IAM-06: Cross-session boundary	?				
19	IAM-07: Delegation chain enforcement	?				
20	IAM-08: Credential scope narrowing	?				
21	IAM-09: Multi-tenant isolation	?				
22	DS-01: Data classification	?				
23	DS-02: Inference protection	?				
24	DS-03: Memory sanitisation	?				
25	DS-04: Data minimisation	?				
26	DS-05: Training data governance	?				
27	DS-06: Output validation	?				

#	Control	Assessed	Score (1-5)	Maturity (L1-L4)	Key Artifact Obtained	Notes
28	DS-07: Artifact publication control	?				
29	TP-01: Tool inventory	?				
30	TP-02: Tool access control	?				
31	TP-03: API gateway security	?				
32	TP-04: Tool output validation	?				
33	TP-05: Pipeline integrity	?				
34	TP-06: Dependency scanning	?				
35	TP-07: Cross-tool dependency analysis	?				
36	TP-08: Infrastructure-isolation mode	?				
37	TP-09: Explicit tool registration	?				
38	TP-10: Inbound	?				

#	Control	Assessed	Score (1-5)	Maturity (L1-L4)	Key Artifact Obtained	Notes
	control-plane protection					
39	TP-11: Agent browser & content-rendering isolation	?				
40	TP-12: Tool-call provenance & dispatch verification	?				
41	TP-13: Dependency-install provenance verification	?				
42	TP-14: Skill/ plugin payload integrity and instruction-channel isolation	?				
43	TP-15: In-process code-execution sandbox sufficiency	?				
44	MIR-01: Agent activity logging	?				
45	MIR-02: Anomaly detection	?				

#	Control	Assessed	Score (1-5)	Maturity (L1-L4)	Key Artifact Obtained	Notes
46	MIR-03: Prompt audit log	?				
47	MIR-04: IR playbooks	?				
48	MIR-05: Reporting integration	?				
49	MIR-06: Forensic readiness	?				
50	GRM-01: AI governance body	?				
51	GRM-02: AI risk register	?				
52	GRM-03: Ethical use policy	?				
53	GRM-04: Third-party AI risk	?				
54	GRM-05: Regulatory mapping	?				
55	GRM-06: Board reporting	?				
56	EE-01: Execution boundary enforcement	?				
57	EE-02: Infrastructure	?				

#	Control	Assessed	Score (1-5)	Maturity (L1-L4)	Key Artifact Obtained	Notes
	API access control					
58	EE-03: Resource usage limiting	?				
59	EE-04: Evaluation sandbox integrity	?				
60	EE-05: Host-trusted file injection prevention	?				
61	EE-06: Fail-closed sandbox operation	?				
62	EE-07: Control-plane config integrity	?				
63	EE-08: Evaluation-harness isolation & integrity	?				

Pillar Maturity Summary

Pillar	Lowest Control Score	Maturity Level	Regulators Met	Next Action
MS				
IAM				
DS				
TP				

Pillar	Lowest Control Score	Maturity Level	Regulators Met	Next Action
MIR				
GRM				
Overall	***(min of above)***			

SHIELD-AI Assessment Guide v1.15 – September 28, 2026 (aligned to framework v1.15) Version history: v1.0 July 2026 (initial release); refreshed for framework v1.8 August 2026 (60 controls); refreshed for framework v1.9 August 31, 2026 (61 controls, TP-13); refreshed for framework v1.10 September 1, 2026 (62 controls, TP-14; FF-01/FF-06/FF-07 adopted into Section 8 methodology and Phase 2 evidence collection); refreshed for framework v1.11 September 7, 2026 (62 controls, MS-08/EE-07 guidance extensions); refreshed for framework v1.12 September 19, 2026 (63 controls, TP-15; EE-01/TP-06/EE-07 guidance extensions); refreshed for framework v1.14 September 25, 2026 (63 controls; MS-08/EE-08/GRM-04 guidance extensions for INC-60..INC-62); refreshed for framework v1.15 September 28, 2026 (63 controls; EE-08/EE-05/TP-15 guidance extensions for INC-64..INC-65) *For use by SHIELD-AI Practitioners and Assessors Security Architecture Practice*